

# Healthcare Data Privacy and Security

Giuseppe Pisano  
g.pisano@unibo.it

August, 2026



S.K.I.L.L.E.D — AID013244/04/2

Strategic Knowledge and Inclusive Lifelong Learning in the health sector for youth Employability and Development

- 1 Security Foundations
  - Running Scenario
  - Security Objectives
  - Components and Networks
  - Impact and Risk
  - Vulnerabilities and Attacks
  - Threat Classes
  - Attack Surface
  - Design and Policy
- 2 Cryptography
  - Hash Functions
  - Encryption Basics
  - Symmetric Encryption
  - Diffie-Hellman Key Agreement
  - Message Authentication Codes
  - Asymmetric Encryption with RSA
  - Digital Signatures

- Digital Envelopes

3

## Access Control

- Access Control Purpose
- Authentication, Authorization, Audit
- Policy Design Principles
- Role-Based Access Control

4

## OpenHospital Access-Control Lab

- Lab Goal
- Install and Start
- First Login and Exploration
- Groups as Roles
- Test the Policy
- Lab Recap

5

## Privacy and Data Protection

- From Privacy to Data Protection
- Data Protection Definitions

- Fair Processing Principles

## 6 Operational Security

- Healthcare Data Handling Mindset
- Scams and Social Engineering
- Accounts, Passwords, and Multi-Factor Authentication
- Devices, Updates, and Workspaces
- Networks and Remote Work
- Backups, Ransomware, and Reporting
- Practical Daily Checklist

## 7 Glossary and Resources

- Final Glossary
- Additional Materials

# Security Foundations

## Running Scenario

## Section Context: Running Scenario

### What we are talking about

Before introducing formal security concepts, we establish a shared hospital environment. This keeps the lesson practical: every definition will be connected to a concrete clinical workflow, system, user, or failure mode.

### Why it matters

In healthcare, security decisions are never abstract. A control that looks reasonable on paper can affect triage, medication delivery, lab turnaround time, or patient trust.

# The Hospital We Will Use

## Running example: St. Isidore Hospital

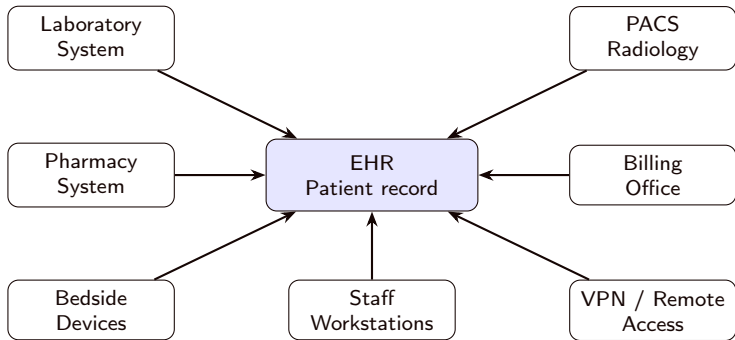
St. Isidore is a mid-size hospital with an emergency department, wards, a laboratory, radiology, pharmacy, billing office, and a small IT team.

## Digital systems

The hospital uses an **EHR**, a **laboratory system**, a **PACS** for medical images, a **pharmacy system**, staff laptops, Wi-Fi, remote access for doctors, and a few connected medical devices.



# Scheme: Hospital Digital Ecosystem



## Reading the scheme

The EHR is central, but security depends on every connected system, user, and network path.

# Why This Scenario Matters

## Key idea

Security in healthcare is not only about protecting computers. It protects **patients, clinical decisions, care continuity, and trust.**

## Hospital example

If the EHR is unavailable during a night shift, clinicians may not see allergies, medications, or recent lab results. A technical failure becomes a *patient-safety* issue.

# Recap: Running Scenario

## Takeaways

- We will use **St. Isidore Hospital** as the running example throughout the lesson.
- The hospital combines clinical systems, administrative systems, networks, devices, and people.
- Security protects *care delivery*, not only servers and databases.

## Security Objectives

## Section Context: Security Objectives

### What we are talking about

This section explains the goals security is trying to achieve. The key question is: *what does it mean for a hospital system to be secure?*

### Hospital lens

For St. Isidore, a secure EHR is not merely hidden from outsiders. It must be readable by the right clinicians, accurate enough to support care, available during work, and traceable when used.

# Computer Security

## Definition

Computer security is the protection provided by an information system to preserve the security objectives of the system and its resources. NIST frames the core objectives as **confidentiality**, **integrity**, and **availability** [National Institute of Standards and Technology, 2004].

## Hospital example

St. Isidore must protect patient records, clinical software, network links, staff accounts, medical images, backup systems, and devices used at the bedside.

# System Resources

## Concept

A system resource is anything the organisation depends on to deliver information services.

- **Hardware:** servers, laptops, scanners, network devices.
- **Software:** EHR, PACS, pharmacy and laboratory systems.
- **Data:** clinical notes, lab results, images, prescriptions.
- **Telecommunications:** Wi-Fi, VPN, internal network, Internet links.

## Hospital example

An MRI image is data; the PACS is software; the storage server is hardware; the link between radiology and the ward is telecommunications.

# The CIA Triad

## Core model

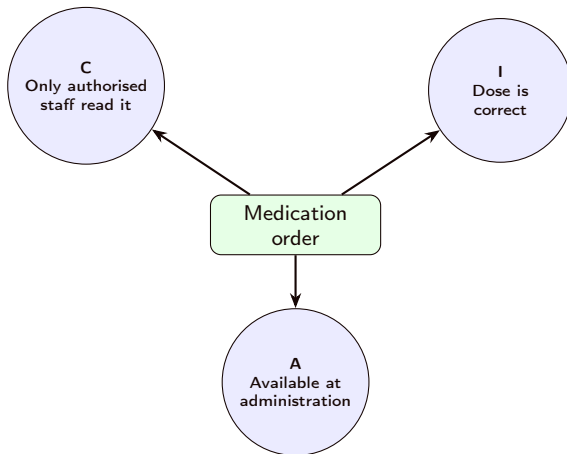
The CIA triad summarises three central security goals: **confidentiality**, **integrity**, and **availability**.

## Hospital example

For a medication order, **confidentiality** means only authorised staff can see it; **integrity** means the dose is not changed incorrectly; **availability** means the order is reachable when the nurse administers treatment.



# Scheme: CIA for a Medication Order



**Takeaway:** the same clinical object must satisfy all three goals at once.

# Confidentiality

## Concept

**Confidentiality** means that information is accessed and disclosed only according to authorised rules.

- It is not secrecy from everyone.
- It is *controlled disclosure* to the right people for the right purpose.

## Hospital example

An emergency doctor may view a patient's allergies. A billing clerk may view insurance data. Neither should automatically see psychotherapy notes unrelated to their role.

# Privacy

## Concept

**Privacy** concerns how personal information is collected, stored, used, shared, and retained.

- Confidentiality protects access to information.
- Privacy also asks whether the information should be processed at all.

## Hospital example

A research team may need aggregated diabetes statistics. Privacy requires minimisation, consent or another lawful basis, and removal of unnecessary identifiers.

# Data Integrity

## Concept

**Data integrity** means that information is accurate, complete, and modified only through authorised and expected processes.

## Hospital example

If a patient's allergy to penicillin is deleted or changed, the record may still be confidential and available, but it is no longer safe to trust.

# System Integrity

## Concept

**System integrity** means that the system performs its intended functions without unauthorised manipulation.

## Hospital example

The pharmacy system should calculate interactions and dosage warnings according to approved rules. If malware changes those rules, the system may give unsafe recommendations.

# Availability

## Concept

**Availability** means that information and services are reachable when they are needed.

- Outages matter.
- Severe slowness also matters.
- Missing dependencies can break a service even if the application itself is healthy.

## Hospital example

If the EHR login service fails, clinicians cannot access records even if the EHR database is still intact.

# Authenticity

## Concept

**Authenticity** gives confidence that a user, device, message, or data source is genuine.

## Hospital example

When the lab system sends a potassium result to the EHR, the EHR must know it really came from the laboratory system, not from a forged message.

# Accountability

## Concept

**Accountability** links actions to identifiable entities. It supports audit, investigation, deterrence, and legal responsibility.

## Hospital example

If a celebrity patient is admitted, audit logs should show which staff members opened the record, when, and from which workstation.



# Recap: Security Objectives

## Takeaways

- **Confidentiality** controls who can see sensitive information.
- **Integrity** keeps data and system behaviour trustworthy.
- **Availability** keeps clinical services reachable when needed.
- **Authenticity** and **accountability** make actions reliable and traceable.

## Hospital checkpoint

A medication order is secure only if it is seen by authorised staff, unchanged, available at administration time, issued by a genuine clinician, and auditable afterwards.

## Components and Networks

# Section Context: Components and Networks

## What we are talking about

This section looks at where threats land in a real system: hardware, software, data, and communication lines. Network security matters because hospital systems are connected by many paths and dependencies.

## Hospital lens

An EHR outage may start with a stolen laptop, a vulnerable application, corrupted data, or a network attack. Understanding the component helps choose the right control.

# Hardware Threats

## Concept

Hardware is especially exposed to physical threats: theft, damage, tampering, and loss.

## Hospital example

A laptop containing cached patient data is stolen from a clinic room. Full-disk encryption and remote wipe reduce confidentiality risk.

# Software Threats

## Concept

Software can be deleted, copied, misconfigured, or modified so that it behaves differently from what users expect.

## Hospital example

A malicious browser extension on a workstation captures EHR session data. Application allowlisting and endpoint monitoring help reduce this risk.

# Data Threats

## Concept

Data must be protected for confidentiality, integrity, and availability at the same time.

## Hospital example

Backups protect availability, access control protects confidentiality, and audit trails help detect unauthorised modification of patient records.

# Communication-Line Threats

## Concept

Network communication can be read, blocked, delayed, modified, duplicated, or reordered.

## Hospital example

A lab result message delayed between the laboratory system and the EHR may cause clinicians to act on outdated information.

# Passive Network Attacks

## Concept

Passive network attacks observe communication without changing it. They are hard to detect because systems continue to work normally.

## Hospital example

Traffic analysis shows that a VIP patient's room communicates frequently with oncology and radiology, revealing sensitive context without reading message contents.



# Active Network Attacks

## Concept

Active network attacks modify traffic, create false traffic, or prevent normal communication.

## Hospital example

An attacker performs a replay attack by resending an old authentication message from a medical device. Fresh nonces, timestamps, and mutual authentication reduce this risk.

# Denial of Service

## Concept

**Denial of service** prevents legitimate users from accessing a channel, system, or service.

## Hospital example

If the medication-ordering module becomes unavailable, nurses may switch to paper procedures. That fallback must be planned, trained, and reconciled later.

# Recap: Components and Networks

## Takeaways

- Hardware, software, data, and networks fail in different ways.
- Network traffic exposes both **content** and **metadata**.
- Passive attacks are hard to notice because they do not alter traffic.
- Active attacks require prevention, detection, response, and fallback procedures.

## Hospital checkpoint

The lab-to-EHR connection must protect confidentiality, integrity, and availability because delayed or altered results can change clinical decisions.

## Impact and Risk

## Section Context: Impact and Risk

### What we are talking about

This section connects security problems to consequences. We move from *what could happen* to *how bad it would be* and *how we decide what to prioritise*.

### Hospital lens

St. Isidore cannot protect every asset with the same intensity. The visitor parking page and the medication-ordering module need different levels of protection because their failures have different clinical impact.

# Impact Levels

## Concept

Impact describes how harmful a security incident would be. NIST FIPS 199 uses **low**, **moderate**, and **high** impact levels [National Institute of Standards and Technology, 2004].

## Hospital example

The public cafeteria menu has low security impact. The EHR medication module has high impact because failure may affect patient treatment.

# Low Impact

## Low impact

The incident causes limited adverse effects. The organisation can still perform its primary functions, perhaps with reduced efficiency.

## Hospital example

The hospital public website loses the page listing visitor parking instructions. This is annoying, but it does not stop care delivery.

# Moderate Impact

## Moderate impact

The incident causes serious adverse effects, such as significant disruption, financial loss, or non-life-threatening harm.

## Hospital example

The appointment booking system is down for a day. Clinics continue, but staff must reschedule patients manually and delays accumulate.



# High Impact

## High impact

The incident causes severe or catastrophic effects, including long-term mission failure, major loss, severe injury, or death.

## Hospital example

Ransomware disables the EHR, laboratory results, and pharmacy ordering during emergency care. The hospital must switch to paper while treating critical patients.

# Impact Depends on the Security Goal

## Concept

The same asset can have different impact levels for confidentiality, integrity, and availability.

## Hospital example

A public ward phone number has low confidentiality impact, moderate availability impact during family coordination, and low integrity impact unless it redirects patients to the wrong service.

# Why Security Is Difficult

## Concept

Security requirements sound simple, but the mechanisms interact with technology, workflow, people, physical space, and law.

## Hospital example

Multi-factor authentication protects remote EHR access. But if it blocks surgeons during an emergency, the hospital needs an emergency-access procedure that is fast, logged, and reviewed.

# Security Is Asymmetric

## Concept

An attacker may need one exploitable weakness. Defenders must reduce many weaknesses and keep doing so as systems change.

## Hospital example

The IT team patches servers, trains staff, segments networks, reviews logs, and tests backups. An attacker may only need one unpatched VPN appliance or one successful phishing email.

# Core Terms

## Vocabulary

The Internet security glossary defines key terms used across security practice [Shirey, 2007].

- **Asset:** something valuable to protect.
- **Threat:** a possible cause of harm.
- **Vulnerability:** a weakness that can be exploited.
- **Attack:** a deliberate attempt to violate security.
- **Countermeasure:** a control that reduces risk.

# Core Terms in the Hospital

## Hospital example

**Asset:** EHR database.

**Threat:** ransomware group.

**Vulnerability:** exposed remote desktop service.

**Attack:** brute-force login followed by malware deployment.

**Countermeasure:** VPN, MFA, account lockout, monitoring, backups.

## Takeaway

Precise language helps teams discuss incidents without mixing up causes, weaknesses, actions, and consequences.

# Risk

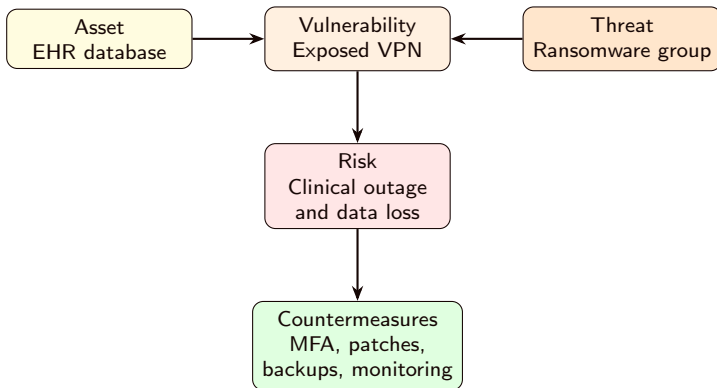
## Concept

**Risk** is the expected loss when a threat exploits a vulnerability and causes impact. NIST SP 800-30 relates risk to threat sources, vulnerabilities, likelihood, and impact [Initiative, 2012].

## Hospital example

An exposed VPN service is risky when attackers are actively exploiting that product and the VPN allows access to clinical systems.

# Scheme: From Weakness to Risk



## Reading the scheme

Risk emerges when a valuable hospital asset is reachable through an exploitable weakness.



# Risk Matrix

## Concept

A risk matrix compares **likelihood** and **impact**. It is a communication tool, not a mathematical proof.

## Hospital example

A rare failure in a public display screen may be low priority. A likely phishing campaign against nurses with access to medication orders deserves immediate attention.

# Estimating Likelihood

## Concept

**Likelihood** is an informed judgement about how plausible an event is in a defined time period. It should combine evidence about the threat, the weakness, and the hospital environment.

- **Threat activity:** are attackers currently exploiting this kind of target?
- **Exposure:** is the vulnerable system reachable from the Internet, VPN, Wi-Fi, or vendors?
- **Control strength:** are MFA, patches, monitoring, and segmentation effective?
- **History:** has the hospital or a peer organisation seen similar incidents?

# Likelihood in the Hospital

## Hospital example

For St. Isidore, phishing against staff is **high likelihood**: it is common, cheap, and targets busy users. Theft of a server from the data centre is **low likelihood**: physical access is restricted and monitored.

## Practical rule

Do not estimate likelihood from intuition alone. Use logs, vulnerability scans, incident history, threat intelligence, audit findings, and knowledge of clinical workflows.

# Example Risk Matrix

|                          | Low impact                        | Moderate impact                    | High impact                                |
|--------------------------|-----------------------------------|------------------------------------|--------------------------------------------|
| <b>High likelihood</b>   | Phishing email to generic mailbox | Phishing nurses with portal access | Exploited reaching systems<br>VPN clinical |
| <b>Medium likelihood</b> | Public screen misconfiguration    | Appointment system outage          | Malware on ward workstation                |
| <b>Low likelihood</b>    | Cafeteria page defacement         | Theft of encrypted laptop          | Data-centre fire with tested failover      |

## Reading the matrix

Items in red or orange are discussed first. Green items are not ignored, but they usually receive lighter controls or later treatment.

# Residual Risk

## Concept

**Residual risk** is the risk that remains after countermeasures are applied.

## Hospital example

MFA reduces account takeover, but a tired doctor may still approve a fraudulent push request. Training, number matching, monitoring, and help-desk procedures reduce the remaining risk.

# Recap: Impact and Risk

## Takeaways

- Impact levels help separate minor inconvenience from patient-safety risk.
- Risk combines **asset value**, **threats**, **vulnerabilities**, likelihood, and impact.
- A risk matrix helps prioritise, but it does not remove uncertainty.
- Controls reduce risk; they rarely remove it completely.

## Hospital checkpoint

The same ransomware threat is more urgent when it can reach the EHR, lab, and pharmacy systems than when it can only affect an isolated public kiosk.

## Vulnerabilities and Attacks

# Section Context: Vulnerabilities and Attacks

## What we are talking about

This section explains how security failures start. A vulnerability is the weakness; an attack is the attempt to exploit it; the attacker may be inside or outside the organisation.

## Hospital lens

At St. Isidore, the same patient record can be threatened by a stolen password, a curious employee, an exposed server, or a malware-infected workstation. The defence depends on the attack path.



# Vulnerability Categories

## Concept

Vulnerabilities can be grouped by the security property they endanger.

- **Corrupted:** integrity is lost.
- **Leaky:** confidentiality is lost.
- **Unavailable:** availability is lost.

## Hospital example

A wrong lab value is *corrupted*; a public folder with patient PDFs is *leaky*; a locked ransomware database is *unavailable*.

# Active Attacks

## Concept

An **active attack** alters resources or influences system behaviour.

## Hospital example

An attacker changes a discharge summary, modifies DNS settings, installs malware on a nurse workstation, or floods a patient portal until it stops responding.

# Passive Attacks

## Concept

A **passive attack** observes or collects information without directly changing the system.

## Hospital example

Someone connected to an insecure guest Wi-Fi captures unencrypted traffic and learns which devices communicate with the radiology system.

# Insider Attacks

## Concept

An **insider attack** is performed by someone who already has authorised access but uses it in an unauthorised way.

## Hospital example

A staff member opens the record of a neighbour without a care-related reason. The account is valid; the use is not.

# Outsider Attacks

## Concept

An **outsider attack** comes from outside the security perimeter: criminals, opportunistic attackers, hostile actors, or compromised third parties.

## Hospital example

A criminal group sends phishing emails to hospital staff to steal credentials and access the EHR remotely.

# Preventive Countermeasures

## Concept

**Preventive controls** try to stop an attack before it succeeds.

## Hospital example

St. Isidore uses MFA for remote access, network segmentation between guest Wi-Fi and clinical systems, endpoint protection, patched servers, and role-based access control.

# Detect and Recover

## Concept

**Detect-and-recover controls** assume that prevention can fail. They identify attacks, contain damage, and restore trustworthy service.

## Hospital example

The security team monitors unusual EHR access, isolates infected laptops, restores clean backups, and reviews logs after an incident.

# Recap: Vulnerabilities and Attacks

## Takeaways

- Vulnerabilities can make systems **corrupted**, **leaky**, or **unavailable**.
- Active attacks change systems; passive attacks observe them.
- Insider attacks misuse legitimate access; outsider attacks cross the perimeter.
- Prevention matters, but detection and recovery are essential when prevention fails.

## Hospital checkpoint

An exposed VPN, a stolen account, and weak backup protection are different weaknesses, but together they can form one ransomware path.



## Threat Classes

## Section Context: Threat Classes

### What we are talking about

This section classifies common threat patterns. Instead of memorising isolated attack names, we connect each threat to the security property it damages: confidentiality, integrity, availability, or control of resources.

### Hospital lens

The hospital scenario helps distinguish *leaking a record*, *changing a record*, *blocking a service*, and *taking over a system*. Each failure calls for different controls and response procedures.

# Unauthorised Disclosure

## Concept

**Unauthorised disclosure** is a confidentiality threat: information reaches an entity that should not receive it.

## Hospital example

A misconfigured cloud storage bucket exposes discharge letters containing patient names, diagnoses, and medication lists.

# Exposure

## Concept

**Exposure** can be intentional or accidental. It occurs when sensitive information is made visible to the wrong audience.

## Hospital example

A spreadsheet of HIV clinic appointments is emailed to a public mailing list by mistake.

# Interception

## Concept

**Interception** occurs when communication is observed in transit.

## Hospital example

An attacker captures unencrypted traffic between an old bedside device and a monitoring server.

# Inference

## Concept

**Inference** means deriving sensitive information from indirect signals, partial data, or metadata.

## Hospital example

Even if message contents are encrypted, repeated traffic from oncology to a patient's room at specific times may reveal sensitive clinical context.

# Intrusion

## Concept

**Intrusion** is unauthorised access that bypasses controls and reaches protected resources.

## Hospital example

An attacker exploits a vulnerable patient portal and downloads appointment histories from the backend database.

# Masquerade

## Concept

**Masquerade** is impersonation: one entity pretends to be another.

## Hospital example

A stolen nurse account is used to open patient records. To the EHR, the request looks like it came from the nurse unless stronger authentication and anomaly detection intervene.



# Falsification

## Concept

**Falsification** replaces valid information with false information.

## Hospital example

Changing a blood type, medication dose, or lab result can directly influence clinical decisions. Integrity failures can therefore become safety incidents.

# Repudiation

## Concept

**Repudiation** occurs when someone denies an action, such as sending, approving, or receiving data.

## Hospital example

A physician denies approving a high-risk medication order. Strong authentication, audit logs, and timestamps help reconstruct what happened.

# Disruption

## Concept

**Disruption** threatens availability by preventing normal service.

## Hospital example

A denial-of-service attack makes the patient portal unreachable during vaccination booking. Care continues, but administrative pressure rises quickly.

# Incapacitation

## Concept

**Incapacitation** disables a system or component through physical damage, malware, or severe failure.

## Hospital example

Ransomware encrypts the file server used by radiology. Images cannot be retrieved until recovery procedures start.

# Obstruction

## Concept

**Obstruction** interferes with communication or overloads resources.

## Hospital example

An attacker floods the VPN gateway. Doctors working from home cannot connect to review urgent test results.

# Usurpation

## Concept

**Usurpation** occurs when an unauthorised entity takes control of a logical or physical resource.

## Hospital example

Compromised hospital workstations become part of a botnet and are used to attack another organisation, damaging both security and reputation.

# Recap: Threat Classes

## Takeaways

- **Disclosure** attacks expose information through exposure, interception, inference, or intrusion.
- **Deception** attacks undermine trust through masquerade, falsification, or repudiation.
- **Disruption** attacks reduce availability through incapacity or obstruction.
- **Usurpation** means unauthorised control of hospital resources.

## Hospital checkpoint

If a forged lab message is accepted by the EHR, the problem is not only technical: it can affect diagnosis, treatment, auditability, and patient safety.

Attack Surface



## Section Context: Attack Surface

### What we are talking about

This section brings the lesson together by asking where an attacker can touch the hospital environment. Attack surface analysis maps entry points, weaknesses, paths, controls, and assets.

### Hospital lens

For St. Isidore, the attack surface includes technology and people: VPN, email, patient portal, medical devices, vendor access, APIs, Wi-Fi, cloud systems, and staff workflows.

# Attack Surface

## Concept

The **attack surface** is the set of points where an attacker can interact with, influence, or observe a system.

## Hospital example

The patient portal, VPN, Wi-Fi, email, medical devices, vendor support accounts, APIs, and staff workstations are all part of the hospital attack surface.

# Network Attack Surface

## Concept

The network attack surface includes exposed ports, services, protocols, remote access paths, and network boundaries.

## Hospital example

An old remote administration service left open on a radiology server creates a direct path into a clinical network segment.

# Software Attack Surface

## Concept

The software attack surface includes input channels, APIs, file uploads, web forms, parsers, legacy components, and configuration interfaces.

## Hospital example

A patient portal upload feature accepts PDF documents. If parsing is vulnerable, a malicious file may compromise the server.

# Human Attack Surface

## Concept

The human attack surface includes phishing, social engineering, unclear procedures, fatigue, and pressure during urgent work.

## Hospital example

A caller pretending to be from IT asks a nurse to approve an MFA prompt. Training and clear help-desk procedures reduce this path.

# Analysing Attack Paths

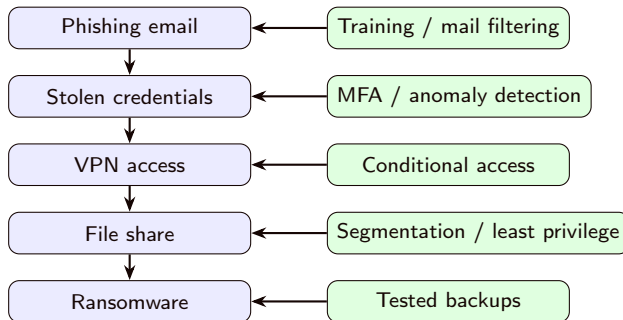
## Concept

Attack surface analysis maps entry points, vulnerabilities, controls, and assets that could be reached.

## Hospital example

Phishing email → stolen credentials → VPN access → file share → ransomware. Controls can interrupt the path at several points.

## Scheme: Example Attack Path



### Takeaway

Controls are stronger when they interrupt the path before attackers reach clinical assets.

# Reducing Attack Surface

## Concept

Reducing attack surface means removing unnecessary exposure and strengthening unavoidable exposure.

## Hospital example

St. Isidore closes unused ports, removes stale accounts, segments medical devices, limits vendor access windows, and monitors remote access.



# Recap: Attack Surface

## Takeaways

- Attack surface is the set of places an attacker can interact with or observe a system.
- Network, software, and human surfaces often connect into one attack path.
- Reducing exposure is as important as strengthening unavoidable exposure.
- Attack-path thinking helps place controls before attackers reach clinical assets.

## Hospital checkpoint

Phishing → stolen credentials → VPN → file share → ransomware is a path. MFA, segmentation, least privilege, monitoring, and backups interrupt it at different points.

## Design and Policy

## Section Context: Design and Policy

### What we are talking about

This section shifts from attacks to design choices. Secure systems are not created only by adding tools; they are shaped by principles, policies, workflows, and evidence that controls actually work.

### Hospital lens

St. Isidore must design access rules, emergency override, remote access, logging, backup, and incident response so that security supports care instead of fighting it.

# Secure Design Principles

## Concept

Classic secure design principles reduce complexity, minimise trust, and make failures safer [Saltzer and Schroeder, 1975].

## Hospital example

St. Isidore applies these principles when designing EHR access, emergency override, remote access, network segmentation, audit logging, and backup recovery.

# Economy of Mechanism

## Principle

Security mechanisms should be as simple as possible, so they can be understood, implemented, and verified.

## Hospital example

A simple role model for nurse, physician, pharmacist, and administrator is easier to review than hundreds of undocumented special permissions.

# Fail-Safe Defaults

## Principle

Access should be denied unless permission is explicitly granted.

## Hospital example

New temporary staff accounts should start with no EHR access. Access is added only after role, department, and supervisor approval are confirmed.

# Complete Mediation

## Principle

Every access should be checked, not only the first one.

## Hospital example

If a doctor changes department, the EHR should re-check access rights on each record request, not rely on permissions cached months earlier.

# Open Design

## Principle

Security should not depend on keeping the mechanism secret. Secrets should be limited to keys, passwords, and credentials.

## Hospital example

The hospital should use well-reviewed encryption protocols rather than a custom “secret” algorithm for transmitting lab results.



# Least Privilege

## Principle

Users, services, and devices should receive only the permissions needed for their tasks.

## Hospital example

A kiosk used for patient check-in should not have permission to browse the full EHR database. If compromised, its limited role reduces damage.

# Separation of Privilege

## Principle

Critical actions should require more than one condition, role, or approval.

## Hospital example

Changing a patient's identity record may require both administrative approval and a separate verification by the medical records office.

# Layering and Defence in Depth

## Principle

**Layering** means using multiple overlapping controls, so one failure does not expose the whole system.

## Hospital example

Remote access uses VPN, MFA, device compliance checks, network segmentation, EHR role checks, and logging. Each layer limits what happens if another layer fails.

# Scheme: Defence in Depth

Training, monitoring, and incident response

Network segmentation and firewall rules

VPN, MFA, and conditional access

Managed device and endpoint protection

Role-based access and break-glass review

Clinical asset: EHR medication module

## Reading the scheme

No single layer is trusted to be perfect. Each layer reduces what an attacker can do next.

# Psychological Acceptability

## Principle

Security controls should be understandable and usable enough that people can follow them during real work.

## Hospital example

If login takes too long during ward rounds, staff may share accounts. A better design protects security while respecting clinical pace.

# Security Policy

## Concept

A security policy turns security goals into organisational rules: who may access what, under which conditions, with what logging and responsibilities.

## Hospital example

The policy states that staff may access records only for care, operations, payment, or approved research. Curiosity access is prohibited even if the account technically works.

# Security Trade-Offs

## Concept

Security must balance protection, usability, cost, performance, legal duties, and patient care.

## Hospital example

Strict session timeouts protect unattended workstations, but overly aggressive timeouts may delay care. The hospital may use badge tap-in, short idle locks, and fast re-authentication.

# Security Lifecycle Overview

## Concept

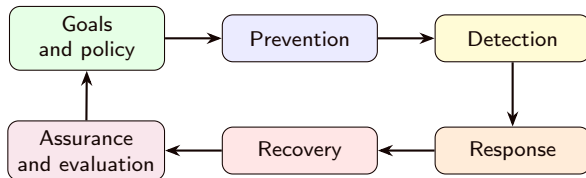
Security is not a one-time setup. It is a **lifecycle**: define what must be protected, prevent what you can, detect what still happens, respond under pressure, recover safely, and evaluate whether the controls actually work.

## Hospital example

St. Isidore does not simply install a firewall and stop. It updates policies, trains staff, monitors alerts, practices ransomware recovery, tests backups, and reviews incidents to improve the next cycle.



# Scheme: Security Lifecycle



## Reading the scheme

Each incident, audit, and recovery test should feed back into better policy and prevention.

# Prevention

## Concept

**Prevention** aims to stop attacks before they succeed.

## Hospital example

Patch management, MFA, network segmentation, secure configuration, and phishing-resistant authentication reduce the chance of compromise.

# Detection

## Concept

**Detection** identifies suspicious activity, misuse, policy violations, or confirmed intrusions.

## Hospital example

An alert triggers when one account opens hundreds of patient records across unrelated wards in ten minutes.

# Response

## Concept

**Response** contains an incident, limits further damage, preserves evidence, and coordinates communication.

## Hospital example

When malware is detected, IT isolates the workstation, disables the account, informs clinical leadership, and checks whether patient care is affected.

# Recovery

## Concept

**Recovery** restores services and data to a trustworthy state after an incident.

## Hospital example

After ransomware, the hospital rebuilds servers from clean images, restores tested backups, and reconciles paper medication orders entered during downtime.

# Assurance

## Concept

**Assurance** is confidence that security measures satisfy their requirements.

## Hospital example

The hospital does not merely assume backups work. It performs restoration tests and records the time needed to recover critical systems.

# Evaluation

## Concept

**Evaluation** checks a system against defined criteria through testing, review, audit, certification, or formal analysis.

## Hospital example

Before buying a new telemedicine platform, St. Isidore reviews encryption, logging, access control, data retention, vendor support, and incident notification terms.

# Recap: Design and Policy

## Takeaways

- Design principles reduce complexity and limit damage when something fails.
- Policy translates security goals into organisational rules and responsibilities.
- Security is a trade-off among protection, usability, cost, performance, and care delivery.
- Prevention, detection, response, recovery, assurance, and evaluation form a lifecycle.

## Hospital checkpoint

An emergency-access feature is acceptable only if it is fast enough for care, limited in scope, logged, reviewed, and tested.



# Cryptography

## Running Example: The Lab Result

We will follow one message through the cryptography section:

Patient 1042, potassium = 6.1 mmol/L, time = 10:32, lab = St.  
Isidore

This is clinically sensitive because it identifies a patient and contains a result that may affect urgent care. Each cryptographic technique answers a different question about this same message: can others read it, can changes be detected, can the sender be trusted, and how are keys obtained?

# Hash Functions

## Section Context: Hash Functions

### What we are talking about

Before we encrypt or authenticate messages, we need the idea of a digest: a compact fingerprint that changes when data changes.

### Hospital lens

When a software update, discharge summary, or configuration file arrives, the hospital needs a way to detect whether the exact bytes changed.

# Hash Functions

## Concept

A **hash function** maps data of variable length to a fixed-length digest. A secure hash acts like a fingerprint of the input.

## Hospital example

The hospital computes a hash of a software update before installation. If the downloaded file has changed, the hash will not match the expected value.

# Properties of Secure Hashes

- **Preimage resistance:** given a digest, it is infeasible to find a matching input.
- **Second-preimage resistance:** given one input, it is infeasible to find a different input with the same digest.
- **Collision resistance:** it is infeasible to find any two different inputs with the same digest.

## Hospital example

These properties help protect password storage, file-integrity monitoring, and digital signatures.

# Hashing Passwords

## Concept

Systems should store password verifiers, not plaintext passwords. In practice this requires password-hashing schemes with salts and work factors, not a bare fast hash.

## Hospital example

If an attacker steals the staff account database, salted password hashes make password recovery harder than if plaintext passwords were stored.

# File Integrity Monitoring

## Concept

Hash values can help detect whether important files changed. The reference hashes must be protected from attackers.

## Hospital example

St. Isidore stores trusted hashes of critical EHR configuration files. A nightly check alerts IT if malware modifies them.



# SHA



## Standard family

The Secure Hash Standard defines SHA algorithms used in many security applications [National Institute of Standards and Technology, 2015]. Algorithm choice matters because older hashes may become weak over time.

## Hospital example

The hospital prefers modern SHA-2 or SHA-3 based mechanisms where appropriate, and avoids legacy uses of broken hashes in certificates or signatures.

# Recap: Hash Functions

## Takeaways

- Hash functions produce fixed-length fingerprints of data.
- They support file checks, password storage, MACs, and digital signatures.
- Hashes do not hide data: they are not encryption.

## Running Example: Hashing the Result

Before encryption, St. Isidore can compute a hash of the lab-result message.

The hash is a compact fingerprint of the exact message bytes. If someone changes 6.1 mmol/L to 4.1 mmol/L, the hash changes.

The hash does **not** hide the result. It helps detect change, but anyone who can read the original message can still read the patient identifier and clinical value.

# Encryption Basics

# Section Context: Cryptographic Foundations

## What we are talking about

Cryptography transforms information so that only authorised parties can read it, verify it, or trust where it came from. We start with the basic ideas before looking at specific families of algorithms.

## Hospital lens

At St. Isidore, cryptography protects a lab result while it travels, a backup while it is stored, and a prescription order while the pharmacy verifies who sent it.

# Kerckhoffs's Principle

## Principle

The security of a cryptosystem should depend on the secrecy of the **key**, not on the secrecy of the **algorithm** [Kerckhoffs, 1883].

## Hospital example

St. Isidore should not rely on a vendor's secret home-made encryption method. It should rely on well-studied algorithms and protect the hospital's keys carefully.

# What Cryptography Provides

## Core services

Cryptography can support **confidentiality**, **authentication**, **integrity**, and in some systems **anonymity**.

- **Confidentiality**: hiding content from unauthorised readers.
- **Authentication**: verifying identities or sources.
- **Integrity**: detecting unauthorised modification.
- **Anonymity**: reducing linkability to a person or communication path.

# Healthcare Example: One Lab Result

## Hospital example

A potassium result moves from the laboratory system to the EHR. Cryptography can keep the value private, prove it came from the lab, detect changes, and help prevent replay of an old result.

## Takeaway

Encryption is not only about secrecy. Clinical systems also need authenticity, integrity, freshness, and correct ordering.



# Encryption and Decryption

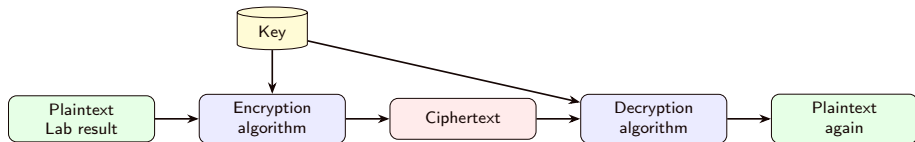
## Concept

**Encryption** transforms plaintext into ciphertext. **Decryption** transforms ciphertext back into plaintext using the correct key.

## Hospital example

Before sending a discharge letter to a referral clinic, the hospital encrypts it. If the message is intercepted, the attacker sees ciphertext rather than patient data.

# Scheme: Encryption Flow



## Reading the scheme

The algorithm may be public. The key is the secret that controls who can decrypt.

# Classical Ciphers

## Concept

Classical ciphers such as the Caesar cipher replace or move symbols according to a simple rule. They are useful for teaching, but not for real security.

## Hospital example

Changing every letter in a patient's name by three positions would not protect the record. Anyone could reverse it once the pattern is recognised.

# Why Simple Ciphers Fail

## Concept

Substitution and transposition ciphers preserve patterns. Attackers can use language statistics, known formats, and repeated phrases to recover meaning.

## Hospital example

Hospital messages often repeat phrases such as “patient ID”, “diagnosis”, or “lab result”. Repeated structure gives attackers clues if the cipher leaks patterns.

# Recap: Cryptographic Foundations

## Takeaways

- Cryptographic security should depend on protected keys, not secret algorithms.
- Encryption turns plaintext into ciphertext; decryption reverses it with the right key.
- Healthcare systems need secrecy, authenticity, integrity, and freshness.
- Simple historical ciphers fail because they leak patterns.

## Running Example: Encrypting the Result

Now the laboratory system encrypts the same lab-result message before sending it to the electronic health record.

The plaintext is the readable result. The ciphertext is what crosses the network. A person who captures the network traffic should not learn that patient 1042 has potassium 6.1 mmol/L.

Encryption protects **confidentiality**. By itself, it does not automatically prove who sent the result or whether the result is fresh.

# Symmetric Encryption

## Section Context: Symmetric Encryption

### What we are talking about

Symmetric encryption uses the **same secret key** for encryption and decryption. It is fast, widely deployed, and central to protecting stored and transmitted healthcare data.

### Hospital lens

When St. Isidore encrypts database backups or file transfers, it commonly uses symmetric cryptography under the hood.



# Symmetric Encryption

## Concept

In symmetric encryption, sender and receiver share one secret key. Anyone with the key can decrypt the protected data.

## Hospital example

The backup system encrypts nightly EHR backups with a hospital-controlled key. Recovery is possible only if that key remains available and protected.

# Components of a Symmetric System

- **Plaintext:** original data.
- **Encryption algorithm:** transforms the plaintext.
- **Secret key:** controls the transformation.
- **Ciphertext:** encrypted output.
- **Decryption algorithm:** reverses the process with the same key.

## Hospital example

The plaintext is an EHR export; the key is stored in a key-management system; the ciphertext is the encrypted backup file.

# Two Requirements for Security

## Concept

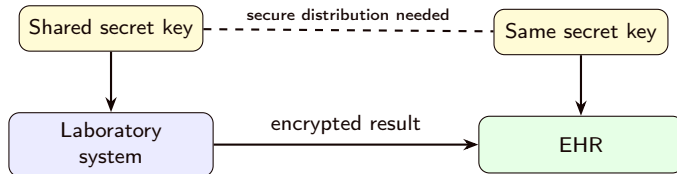
A symmetric system needs both a **strong algorithm** and **secure key handling**.

- The algorithm should resist cryptanalytic and brute-force attacks.
- The key must be generated, distributed, stored, rotated, and retired securely.

## Hospital example

AES is not enough if the encryption key is stored in a shared spreadsheet or left on the same server as the data it protects.

# Scheme: Symmetric Key Sharing



## Takeaway

The difficult part is often not encryption itself, but getting the key safely to the right systems.

# Cryptanalytic Attacks

## Concept

**Cryptanalysis** tries to exploit weaknesses in the algorithm, message structure, or available plaintext/ciphertext examples.

## Hospital example

If every exported report begins with the same header, a weak encryption mode may reveal patterns that help an attacker reason about the protected files.

# Brute-Force Attacks

## Concept

**Brute force** tries possible keys until the output looks like meaningful plaintext. Longer keys make exhaustive search infeasible.

## Hospital example

If archived patient files were encrypted with an obsolete short key, an attacker with copied ciphertext may be able to recover the records later.

# AES



## Modern standard

The Advanced Encryption Standard is a symmetric block cipher with 128-bit blocks and key sizes of 128, 192, or 256 bits [National Institute of Standards and Technology, 2023a].

## Hospital example

AES is commonly used to encrypt backups, databases, disks, VPN traffic, and secure application channels in healthcare environments.

# Recap: Symmetric Encryption

## Takeaways

- Symmetric encryption is fast and widely used.
- Security depends on strong algorithms and strong key management.
- AES is the modern standard example to recognise in this recap.
- A block cipher still needs a safe mode when used on real messages.
- Key exposure compromises every message protected with that key.



## Running Example: A Shared Session Key

For fast protection, the laboratory system and the electronic health record can use the same temporary secret key to encrypt and decrypt the lab-result message.

This is efficient, so it works well for many messages and large files. The central practical question is how both systems obtain the same secret key without exposing it.

If the key is copied into a shared document, emailed to an administrator, or stored beside the data, the encryption may be strong mathematically but weak operationally.

# Diffie-Hellman Key Agreement

# Diffie-Hellman Key Agreement

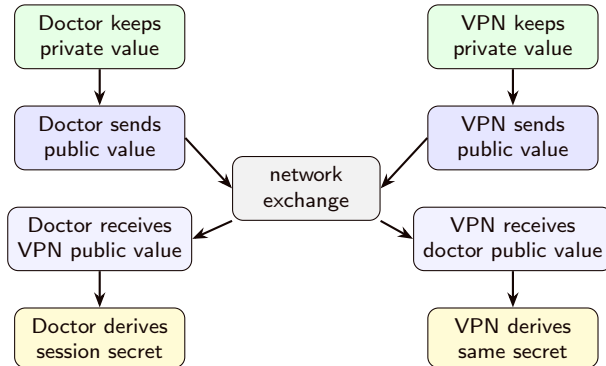
## Concept

Diffie-Hellman allows two parties to establish a shared secret over an insecure channel [Diffie and Hellman, 1976]. By itself, basic Diffie-Hellman does not authenticate who is on the other side.

## Hospital example

A doctor connects to the VPN from home. The protocol can agree on session keys, but certificates and authentication are needed to prevent an attacker from impersonating the hospital.

# Scheme: Diffie-Hellman



## Reading the scheme

Only public values cross the network. Each side keeps its private value local and combines it with the received public value, deriving the same session secret independently.

# Recap: Diffie-Hellman

## Takeaways

- Diffie-Hellman is key agreement, not document encryption.
- The shared secret is derived locally rather than transmitted.
- Authentication is still needed to avoid impersonation.

## Running Example: Agreeing on the Key

Instead of sending the session key directly, the laboratory system and the electronic health record can derive it through a key-agreement protocol such as Diffie-Hellman.

Only public values cross the network. Each side keeps its private value local and independently derives the same session key.

This solves key exchange, but not identity by itself. The electronic health record still needs to know that it is talking to the real laboratory system, not an impostor.

## Message Authentication Codes

# Message Authentication

## Concept

A message is authentic when the receiver can verify its source and detect changes to its content. Good authentication can also check sequence and freshness.

## Hospital example

The EHR should reject a lab result if it was modified, replayed from yesterday, or sent by a system pretending to be the laboratory.



# Why Encryption Alone Is Not Enough

## Concept

Confidentiality does not automatically imply integrity. Some encrypted data can still be reordered, replayed, or tampered with unless authentication is included.

## Hospital example

If encrypted medication-order blocks can be rearranged without detection, the receiver may decrypt valid-looking but clinically wrong content.

# Message Authentication Code

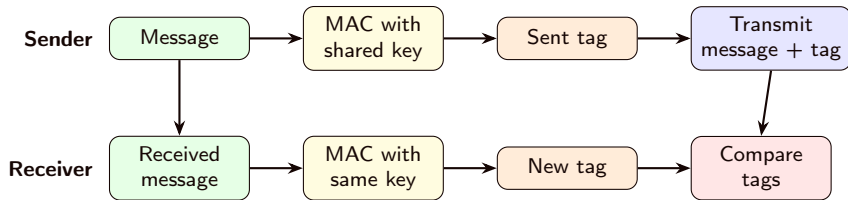
## Concept

A **Message Authentication Code** (MAC) is a short tag computed from a message and a shared secret key. The receiver recomputes the tag and compares it.

## Hospital example

The lab system attaches a MAC to each result message. The EHR verifies the MAC before accepting the result into the patient record.

# Scheme: MAC Verification



## Takeaway

The receiver does not decrypt a MAC. It recomputes the tag from the received message and the shared secret, then compares the two tags.

# Recap: Message Authentication Codes

## Takeaways

- MACs use a shared secret key, so they naturally follow symmetric-key ideas.
- They detect tampering and authenticate messages between systems that share the key.
- They complement encryption: confidentiality alone does not prove integrity.

## Running Example: Authenticating the Result

The laboratory system computes a message authentication code over the lab-result message using the shared secret key.

The electronic health record recomputes the code over the received message. If the two codes match, the system has evidence that the message was not modified and came from a party that knew the shared secret.

This is useful for system-to-system communication, but it does not give public proof to outsiders: both sides share the same secret.

## Asymmetric Encryption with RSA

## Section Context: Asymmetric Encryption

### What we are talking about

Asymmetric encryption uses a public key and a private key to solve a specific problem: sending protected data or a protected session key without first sharing a secret.

### Hospital lens

St. Isidore can publish a receiving service public key. External clinics use it to protect referral packages or the short session keys that protect larger files.

# Asymmetric Keys

## Concept

Each participant has a **public key** that can be shared and a **private key** that must stay secret. What one key does, the paired key can verify or reverse, depending on the scheme.

## Hospital example

The patient portal publishes a certificate containing its public key. The matching private key stays protected on the server or in a hardware security module.



# Confidentiality with Public Keys

## Concept

To send confidential data to Alice, Bob encrypts using Alice's public key. Only Alice's private key can decrypt.

## Hospital example

An external clinic can encrypt a referral package so that only St. Isidore's receiving service can open it.

# Families of Public-Key Algorithms

## What changes between algorithms

Public-key algorithms are not interchangeable names. Each family is built around a hard mathematical problem and is usually designed for one main purpose: **encryption**, **digital signature**, or **key agreement**.

## Hospital example

The patient portal certificate may use one algorithm to sign its identity, while the VPN handshake uses another algorithm to agree on fresh session keys. Both are public-key cryptography, but they do different jobs.

# RSA



## Concept

RSA is based on modular arithmetic with a public modulus. The public key can transform data in one direction, while the private key provides a way to reverse or sign that transformation.

## Hospital example

An external clinic can encrypt a small session key with St. Isidore's RSA public key. Only the hospital private key can unwrap it. The same RSA key family can also sign messages when used with a signature padding scheme.

# RSA in Practice

## Important distinction

RSA should not be used to encrypt large clinical files directly. It is usually used to protect small values, such as a symmetric session key, or to create digital signatures.

## Hospital example

For an imaging report, St. Isidore encrypts the file with AES, then uses RSA only to protect the AES key. This is the digital-envelope pattern used later in the lesson.

# Recap: Asymmetric Encryption

## Takeaways

- Public-key cryptography uses key pairs, not one shared secret.
- Public keys can be shared; private keys must be protected.
- RSA is the main public-key encryption example in this recap.
- It usually works together with symmetric encryption in real systems.



Suppose an external clinic must send the lab-result package to St. Isidore, but the two organizations have not already shared a secret key.

The clinic can encrypt a small session key using St. Isidore's public RSA key. Only St. Isidore's private key should be able to recover that session key.

The clinical data itself is still usually encrypted with a fast symmetric algorithm. RSA is used for the small key, not for the whole medical file.

# Digital Signatures

# Section Context: Digital Signatures

## What we are talking about

Digital signatures use public-key cryptography to verify origin and integrity. The focus here is on what a signature proves, what it does not prove, and how verification works.

## Hospital lens

The hospital must verify that vendor updates, formulary changes, and signed clinical documents really came from the expected source and were not modified.



# Digital Signatures

## Concept

A digital signature is usually created by hashing a message and signing the hash with the sender's private key.

## Hospital example

The pharmacy service signs a formulary update. The EHR verifies the signature before using the new medication rules.

# DSS Signature Algorithms

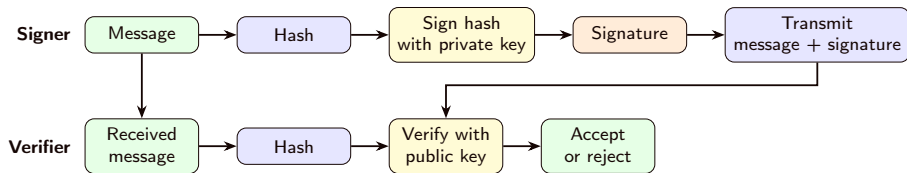
## Algorithm idea

The Digital Signature Standard (DSS) specifies approved digital-signature algorithms [National Institute of Standards and Technology, 2023b]. Current FIPS 186-5 covers **RSA signatures**, **ECDSA**, and **EdDSA**. These are signature mechanisms: they do **not** encrypt data and they do **not** establish shared keys.

## Hospital example

A software vendor can sign a pacemaker gateway firmware update. The hospital verifies the signature before installation to check authenticity and integrity, but the signature itself does not hide the update contents.

# Scheme: Digital Signature



## Takeaway

The signature protects the hash of the message. Verification uses the sender's public key and the freshly computed hash of the received message.

# Recap: Digital Signatures

## Takeaways

- Digital signatures authenticate origin and detect modification.
- The signer uses a private key; verifiers use the matching public key.
- Signatures do not hide content; combine them with encryption when confidentiality is needed.

## Running Example: Signing the Result

The laboratory can digitally sign the lab-result message before the electronic health record accepts it as official.

The signature lets the receiver verify that the approved laboratory service signed the result and that the signed content was not changed afterward.

The signature does **not** hide the potassium value. If the result must remain confidential, signature and encryption must be combined.

## Digital Envelopes

## Section Context: Digital Envelopes

### What we are talking about

Real systems rarely use only one cryptographic primitive. A digital envelope combines fast symmetric encryption with public-key protection of the temporary key.

### Hospital lens

A large imaging report can be encrypted efficiently with a fresh session key, while the session key is protected for the intended specialist using that specialist's public key.

# Digital Envelopes

## Concept

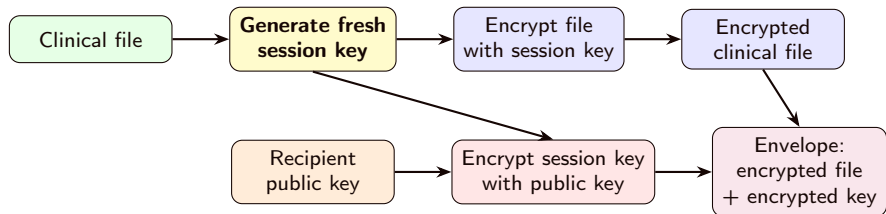
A **digital envelope** combines symmetric and public-key cryptography: encrypt the message with a fresh symmetric key, then encrypt that key with the recipient's public key.

## Hospital example

The hospital sends a large imaging report to an external specialist. The file is encrypted with a fast session key; the session key is protected with the specialist's certified public key.



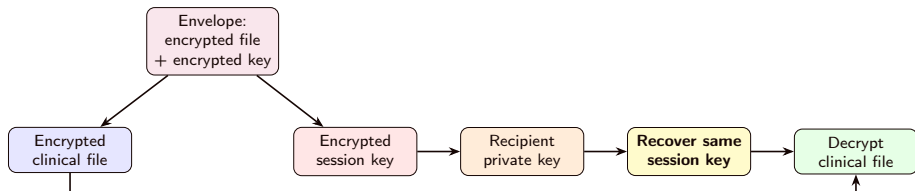
# Scheme: Digital Envelope: Sender



## Reading the scheme

The sender creates a fresh session key. The key encrypts the file, then the recipient's public key encrypts that session key.

# Scheme: Digital Envelope: Receiver



## Reading the scheme

The receiver uses the private key only to recover the session key. The recovered session key then decrypts the clinical file.

## Running Example: Sending the Envelope

The external clinic now sends the complete protected lab-result package to St. Isidore.

The lab result is encrypted with a fresh symmetric session key. That session key is then protected with St. Isidore's public RSA key, so only St. Isidore can recover it with the matching private key.

When St. Isidore receives the envelope, it first recovers the session key, then decrypts the lab result. If the package is also signed or authenticated, the hospital can check both **confidentiality** and **trust** before accepting the result.

# Cryptographic Roles: Recap Map

| Technique      | Main role                       | Hospital example                      |
|----------------|---------------------------------|---------------------------------------|
| AES            | Bulk encryption                 | Backups and clinical files            |
| RSA            | Key wrapping / small encryption | Protecting a session key              |
| Diffie-Hellman | Key agreement                   | Fresh VPN or TLS keys                 |
| Hash functions | Integrity fingerprint           | Checking software updates             |
| MAC            | Shared-secret authentication    | Verifying lab-result messages         |
| RSA signatures | Signature algorithms            | Verifying signed updates or documents |

## Important

Complex systems combine these roles: public-key methods establish trust or protect keys, symmetric encryption protects bulk data, and hashes, MACs, or signatures detect tampering.

# Access Control

## Access Control Purpose

## Section Context: Access Control Purpose

### What we are talking about

Access control is the security function that mediates every attempt to use a protected resource. It prevents unauthorized use, but also prevents **misuse by authorized users**.

### Hospital lens

A cardiologist may be authorized to open the EHR, but that does not mean they may export every patient record, alter medication orders outside their ward, or read celebrity patient files out of curiosity.

# Definition

## Core idea

Access control implements a security policy specifying **who or what** may access a system resource, **which operation** is allowed, and **under which circumstances** [Shirey, 2007].

## Hospital example

The patient portal allows a patient to read their own lab results. It does not allow that patient to read another patient's discharge summary or modify the physician's diagnosis.



# Three Goals

## Access control should

- block access by **unauthorized** subjects;
- stop **authorized** subjects from using resources in unauthorized ways;
- allow legitimate users to complete legitimate work.

## Hospital example

A nurse on the surgical ward should be able to update vital signs for assigned patients, but not change radiology reports or browse psychiatric notes for unrelated patients.

# Why It Is Central

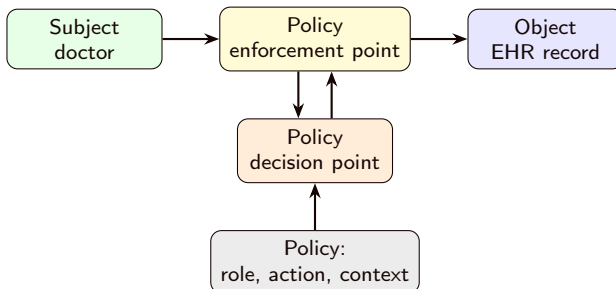
## Security as mediation

Many security mechanisms eventually support an access decision. Firewalls mediate network flows; operating systems mediate files and processes; databases mediate records and fields; applications mediate business actions.

## Hospital example

The same access-control question appears when a clinician logs into the EHR, when a pharmacy system receives a medication order, and when a backup server reads encrypted database snapshots.

# Scheme: Access Request



## Reading the scheme

The subject requests an operation. The enforcement point asks the decision point, which evaluates policy and returns **permit** or **deny**; only permitted operations reach the resource.

# Recap: Access Control Purpose

## Takeaways

- Access control is about **authorized use**, not only login.
- The decision combines subject, object, operation, and context.
- In healthcare, correct access is also a patient-safety requirement.

Authentication, Authorization, Audit

## Section Context: AAA

### What we are talking about

Access control depends on three related functions: **authentication**, **authorization**, and **audit**. They answer different questions and should not be confused.

### Hospital lens

The hospital first checks that “Dr. Rossi” is really Dr. Rossi. Then it checks whether that role may prescribe for this patient. Later, audit logs allow review of what happened.

# Authentication



## Definition

**Authentication** verifies that the entity presenting credentials is who or what it claims to be.

## Hospital example

A doctor uses a password plus a smart card. A medication dispensing cabinet authenticates itself to the pharmacy server using a device certificate.

# Authorization

## Definition

**Authorization** determines which permissions the authenticated entity has for a requested resource and operation.

## Hospital example

After login, the EHR checks whether the doctor has an active care relationship with the patient and whether prescribing is allowed for that department.



# Audit



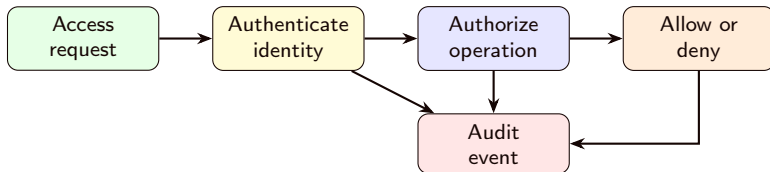
## Definition

**Audit** independently records and reviews security-relevant activity to test whether controls are adequate and whether behavior matches policy.

## Hospital example

The privacy office reviews accesses to VIP patient records and flags staff members who opened records without a treatment, payment, or operations reason.

# Scheme: AAA Flow



## Important

Authentication alone is not enough. A valid identity can still request an operation that policy does not allow.

# Recap: AAA

## Takeaways

- Authentication proves identity or device legitimacy.
- Authorization decides permitted actions.
- Audit creates accountability and supports incident investigation.
- Strong systems keep these functions connected but conceptually separate.

## Policy Design Principles

## Section Context: Policy Design Principles

### What we are talking about

A policy is not only a table of permissions. It also defines assumptions, defaults, delegation rules, conflict handling, and administrative power.

### Hospital lens

Bad policy design can either block urgent care or expose sensitive data. The goal is controlled flexibility: enough access for care, enough restriction for privacy and safety.

# Reliable Input

## Concept

Access control assumes that the inputs used for decisions are reliable: identity, role, device, location, time, and requested operation.

## Hospital example

If the EHR trusts a forged department value, an attacker could make a normal account appear to be part of the intensive-care unit. Reliable identity and context data are part of the control.

# Fine-Grained and Coarse-Grained Rules

## Concept

Policies may be coarse-grained, such as access to an application, or fine-grained, such as access to a single field in a record. Real systems usually need both.

## Hospital example

A billing clerk may open the patient account but should not see psychotherapy notes. A physician may see clinical notes but not modify billing codes.

# Least Privilege

## Concept

**Least privilege** means granting only the permissions needed for the current task [Saltzer and Schroeder, 1975].

## Hospital example

A temporary radiology intern receives read access to imaging studies for assigned patients, not administrator access to the PACS database.



# Separation of Duty

## Concept

**Separation of duty** divides sensitive authority across multiple people or roles so that one person cannot complete a dangerous action alone.

## Hospital example

One administrator requests creation of a high-privilege EHR account, but a different administrator must approve it before the account becomes active.

# Open and Closed Policies

## Two defaults

An **open policy** permits access unless a rule denies it. A **closed policy** denies access unless a rule permits it.

## Hospital example

For clinical records, St. Isidore uses a closed default: no staff member sees a patient file unless a role, assignment, or break-glass emergency rule permits it.

# Policy Conflicts

## Concept

Multiple policies may apply to the same resource. A system must define how conflicts are resolved: for example, whether deny rules override allow rules.

## Hospital example

A doctor is part of the cardiology team, but a special privacy restriction marks a patient record as sensitive. The EHR needs a clear conflict rule before deciding access.

# Administrative Policies and Dual Control

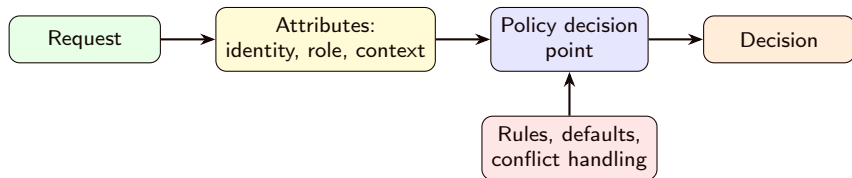
## Concept

Administrative policies specify who may add, remove, or modify permissions. **Dual control** requires two or more people to approve especially sensitive actions.

## Hospital example

Changing the emergency department's access rules requires approval from both IT security and the clinical governance lead.

# Scheme: Access Decision Pipeline



## Reading the scheme

This is the access-control pipeline. **Policy evaluation** is the central step: the decision point combines request attributes with rules, defaults, and conflict handling before returning a decision.

# Recap: Policy Design Principles

## Takeaways

- Least privilege limits blast radius.
- Separation of duty and dual control reduce abuse of sensitive powers.
- Closed policies are usually safer for clinical and personal data.
- Conflict rules and administrative rules are part of the policy.

## Role-Based Access Control

## Section Context: RBAC

### What we are talking about

**Role-Based Access Control** assigns permissions to roles rather than directly to individual users. Users receive roles according to their responsibilities.

### Hospital lens

Hospitals have many users and many resources, but a smaller set of job functions: ward nurse, attending physician, lab technician, pharmacist, registrar, auditor, and system administrator.



# Why RBAC Fits Organizations

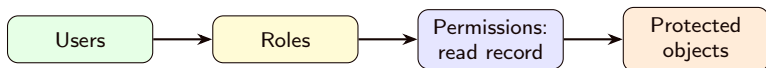
## Concept

Users change often. Permissions attached to job functions change less often. RBAC reduces the administrative burden by managing role assignments and role permissions separately.

## Hospital example

When a new nurse joins the emergency department, IT assigns the “ED nurse” role instead of manually granting every permission needed for triage, vitals, and documentation.

# Scheme: RBAC Mapping



## Reading the scheme

RBAC links users to roles, and roles to permissions. A permission is normally an **operation on an object**, such as reading a patient record.

# RBAC0: Core Model

## Core entities

RBAC0 contains **users**, **roles**, **permissions**, and **sessions**. A session maps a user to the roles activated for a specific task.

## Hospital example

Dr. Rossi may have both “cardiologist” and “researcher” roles, but during a clinical session only the cardiologist role should be active.

# Sessions Matter

## Concept

A user may be assigned multiple roles, but a session should activate only the roles needed now. This supports least privilege.

## Hospital example

The same physician does not need research-export permissions while prescribing medication in the emergency department.

# RBAC1: Role Hierarchies

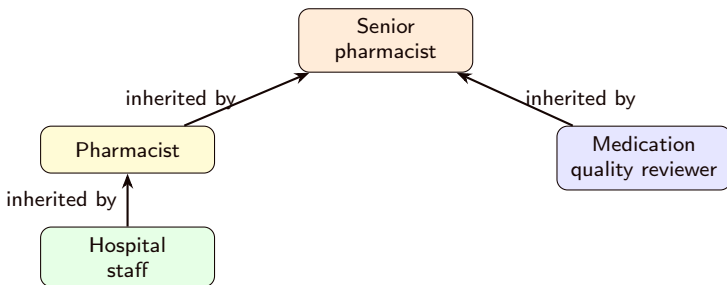
## Concept

RBAC1 adds role hierarchies. A senior role can inherit permissions from subordinate roles, reducing duplication.

## Hospital example

“Senior pharmacist” inherits normal pharmacist permissions and adds authority to approve high-risk medication substitutions.

# Scheme: Role Hierarchy



## Reading the scheme

Arrows point toward the role that **inherits** permissions. Hierarchies simplify shared permissions, but inherited privileges must still respect least privilege.

## RBAC2: Constraints

### Concept

RBAC2 adds constraints that express organizational policy, such as mutually exclusive roles, cardinality limits, and prerequisite roles.

### Hospital example

The same user should not both request and approve creation of a privileged EHR administrator account.

# Mutually Exclusive Roles

## Concept

Mutual exclusion prevents one user or one session from holding roles that should not be combined. This supports separation of duty.

## Hospital example

A user may not be both “controlled-drug inventory clerk” and “controlled-drug audit approver” for the same reporting period.



# Cardinality and Prerequisites

## Concept

**Cardinality** limits how many users may hold a role or how many roles may grant a privilege. **Prerequisite roles** require a user to hold one role before receiving another.

## Hospital example

Only two users may hold the “break-glass policy administrator” role. A clinician must first be an attending physician before becoming an ICU attending.

# RBAC3: Combined Model

## Model family

**RBAC3** is the combined RBAC model family: **RBAC0** core entities plus **RBAC1** hierarchies plus **RBAC2** constraints. It describes a system that uses all of those modelling features together.

## Hospital example

St. Isidore can model normal clinical roles, senior-role inheritance, and constraints on how roles may be assigned or activated.

# NIST RBAC Standard

## Standard terminology

**NIST RBAC** is the standard vocabulary and reference framework. It defines core RBAC, hierarchical RBAC, and separation-of-duty relations, together with administrative, enforcement, and review functions [Ferraiolo et al., 2001].

## Hospital example

Administrators create roles and hierarchies; the EHR checks active session permissions; auditors review which users, roles, permissions, and constraints exist.

# Static and Dynamic Separation of Duty

## Two controls

In NIST RBAC terminology, **static separation of duty** prevents conflicting role assignments. **Dynamic separation of duty** prevents conflicting roles from being active in the same session.

## Hospital example

A person may be assigned both clinician and researcher roles, but cannot activate both when exporting identifiable clinical data for a study.

# Recap: RBAC

## Takeaways

- RBAC assigns permissions to roles, then users to roles.
- Sessions activate only the roles needed for the current task.
- Hierarchies reduce duplication but can accidentally accumulate privilege.
- Constraints express least privilege and separation of duty.

## OpenHospital Access-Control Lab

Lab Goal

## Section Context: OpenHospital Lab

### What we are talking about

This lab turns the access-control recap into a real healthcare application exercise. OpenHospital is a free and open-source hospital information system with users, groups, and application permissions [Informatici Senza Frontiere, 2026a].

### Hospital lens

St. Isidore Hospital is testing whether different staff groups can access only the functions they need: registration, billing, laboratory, pharmacy, and administration.



# Lab Outcome

## By the end

The goal is not to program an access-control model. The goal is to configure a real application's existing controls, then test whether the configured policy behaves like an RBAC-style design.

## Evidence to collect

For at least two test users, record: the group assigned, visible menus, one allowed action, one blocked or unavailable action, and whether logout/login changes the effective permissions.

## Install and Start

# Download OpenHospital

## Official source

Open the OpenHospital GitHub repository and releases page:

- Repository: <https://github.com/informatici/OpenHospital>
- Releases:  
<https://github.com/informatici/openhospital/releases>

## Package to choose

For a normal 64-bit Windows machine, download the **Windows x86\_64 portable** ZIP release.

# Unzip the Portable Package

## Action

Create a dedicated folder, for example `C:\OpenHospital-Lab`. Unzip the downloaded portable ZIP there before running anything. Do not run the application directly from inside the compressed archive.

## Practical note

Keep the extracted folder disposable. If the lab data become confusing, the portable setup can be reset, or a fresh copy can be extracted from the original ZIP.

# Read the Local README

## Before launching

After unzipping, open the README file inside the extracted OpenHospital folder. It contains release-specific startup notes and troubleshooting details.

## External manual

For application usage, keep the official user manual nearby: [https://www.open-hospital.org/wp-content/OH\\_manuals/user/UserManual.html](https://www.open-hospital.org/wp-content/OH_manuals/user/UserManual.html)

For installation and administrative context, keep the official administrator manual nearby: [https://www.open-hospital.org/wp-content/OH\\_manuals/admin/AdminManual.html](https://www.open-hospital.org/wp-content/OH_manuals/admin/AdminManual.html)

[Informatici Senza Frontiere, 2026c, Informatici Senza Frontiere, 2026b].

# Run OpenHospital on Windows

## Action

In the extracted folder, run `oh.bat`. The batch file opens the portable startup console and then launches OpenHospital with the selected settings.

## Expected prompt

The console asks for a choice. Press **Enter** to launch with the default settings: **PORTABLE mode** and demo mode off.

# Startup Console Options

## Useful keys

- Press **Enter**: start with the current default settings.
- Type **D**: toggle demo mode, useful for exploring with sample data.
- Type **X**: clear/reset data; answer **y** to the confirmation prompts.

## Lab caution

Use **X** only in the disposable lab folder. It is useful when you want a clean restart, but it removes the current local data.

## First Login and Exploration



# Login



## Default lab credentials

When the graphical interface starts, log in with:

`admin / admin`

## Security discussion

Default credentials are acceptable for a local disposable lab. In a real hospital deployment, they must be changed immediately and replaced with personal staff accounts.

# Explore Before Restricting

## Action

Use the administrator account to inspect the main modules before creating restricted users. Open the patient, admission, laboratory, pharmacy, billing, and settings areas.

## Hospital lens

This first tour creates the baseline: what can the administrator see, and which functions should not be available to ordinary staff groups?

## Groups as Roles

# Open User and Group Settings

## Action

Log in as admin. Open the settings area and select the user/group management function. Depending on the version and language, this appears as **Settings** and then **Users & Groups**, or a very similar label.

## RBAC interpretation

For this lab, treat OpenHospital **groups** as roles: a user is assigned to a group, and the group determines which application functions are available.

# Create Lab Groups

## Action

Create a small set of groups that match hospital job functions:

- registration: patient registration and search.
- laboratory: lab exams and results.
- pharmacy: medicines and stock.
- cashier: billing and payments.

## Policy idea

Group names should describe work responsibilities, not individual people. This is the RBAC habit: permissions follow the role, then users are assigned to the role.

# Configure Group Permissions

## Action

Open **Settings**, then **Users & Groups**, then **Groups**. Select the group and press **Group Menu**. OpenHospital shows the available functions as a tree: **main** is the trunk, blue nodes are menus/windows, and black nodes are buttons/functions

[Informatici Senza Frontiere, 2026c, Informatici Senza Frontiere, 2026b].

## Example policy

Double-click each branch or leaf to enable or disable it for the selected group. For example, laboratory should access lab workflow functions, but not billing, pharmacy stock, or user/group settings. cashier should access billing, but not lab-result entry.

# Create Test Users

## Action

Create one user for each group and assign the user to the intended group:

| User    | Group        | What to test                       |
|---------|--------------|------------------------------------|
| reg01   | registration | patient admission                  |
| lab01   | laboratory   | lab functions                      |
| pharm01 | pharmacy     | pharmacy functions                 |
| cash01  | cashier      | billing read functions, no editing |

Test the Policy



# Logout/Login Test

## Method

After creating or changing a user or group, log out from admin and log in as the test user. If a permission does not appear to change, log out and back in again before assuming the setting failed.

## Why this matters

Access decisions often depend on the current session. A user may not receive changed permissions until a new login session is created.

# Allowed and Denied Checks

## For each test account

- Confirm which menus are visible.
- Try one action the group should be allowed to perform.

## Hospital example

Log in as lab01. Lab functions should be usable. Billing or user/group settings should be unavailable or denied.

## Lab Recap

# Recap: OpenHospital Lab

## Takeaways

- OpenHospital provides a realistic healthcare access-control exercise.
- Groups can be interpreted as RBAC-style roles for teaching purposes.
- Administrators configure policy; they normally do not implement access-control algorithms.
- Logout/login testing is essential after changing permissions.

# Privacy and Data Protection

# How This Lesson Progresses

## Learning path

We move from the idea of **privacy** as private life, to **data protection** as control over information, and finally to concrete duties for healthcare systems that process patient data.

## Hospital storyline

St. Isidore Hospital wants to use electronic health records, laboratory systems, telemedicine, research datasets, and AI triage support. Each system may be useful, but each changes who can see, copy, combine, or infer sensitive information about patients.

# From Privacy to Data Protection

# Section Context: From Privacy to Data Protection



## What we are talking about

Privacy began as protection against unwanted intrusion into private life. In digital healthcare, the problem expands: patients may not only be watched; their data can be stored, linked, reused, exported, profiled, and breached.

## Hospital lens

A doctor overhearing private symptoms in a corridor is a privacy problem. A database exporting lab results to an insurer without a valid reason is a data protection problem.



# Origins: The Right to Be Let Alone

## Classical idea

Modern privacy discourse is often traced to Warren and Brandeis and the idea of a right to be “let alone” [Warren and Brandeis, 1890]. This model protects private life, habits, writings, images, family life, and reputation from unjustified exposure.

## Running example

If a hospital employee shares a celebrity patient’s ward photo with a newspaper, the harm is not only security failure. It is an invasion of private life and dignity.

# Privacy as a Fundamental Right

## Human-rights dimension

Privacy becomes more than a private-law claim. It protects autonomy, family life, correspondence, home, dignity, and democratic freedom. International and European instruments frame it as a right against arbitrary interference [United Nations, 1948, Council of Europe, 1950].

## Running example

A public hospital is part of the state. If it centralizes patient records, the issue is not only employee curiosity; public power must also be constrained by law, necessity, and safeguards.

# Decision Privacy and Information Privacy

## Two faces

**Decision privacy** protects autonomy in intimate and family choices.

**Information privacy** protects control over the circulation of information about those choices.

## Running example

A patient's decision to seek reproductive care involves decision privacy. The record of that visit, the prescription, billing code, and appointment reminder involve information privacy.

# The Shift to Data Protection

## Digital turning point

From the 1970s onward, privacy law increasingly focused on personal data. The key question becomes: who may collect, use, connect, retain, disclose, or delete information relating to a person?

## Running example

St. Isidore Hospital may need to share data between emergency care and the laboratory. Data protection does not simply say “never share”; it asks whether the sharing has a purpose, valid justification, limits, security, transparency, and accountability.

# Privacy and Data Protection Scheme



## Reading the scheme

Privacy protects private life. Data protection adds governance for the life cycle of information.

# Recap: Privacy and Data Protection

## Takeaways

- Privacy is not only secrecy; it protects autonomy and dignity.
- Data protection focuses on the circulation and use of personal information.
- Healthcare needs controlled data sharing, not total data isolation.

## In St. Isidore Hospital

St. Isidore must protect patients from exposure while still allowing data to move safely for care.

# GDPR as a Source of Concepts

## Position of this section

Regulation (EU) 2016/679, the **General Data Protection Regulation** (GDPR), is used here as a source for common data-protection **definitions** and **principles** [European Union, 2016]. The point is not to study European law in detail, but to learn vocabulary that helps read many privacy and health-data rules.

## Why it is useful

GDPR makes many core ideas explicit: personal data, processing, controller, processor, purpose limitation, minimization, transparency, rights, accountability, and safeguards.

## Data Protection Definitions



## Section Context: Data Protection Definitions

### What we are talking about

Modern data protection uses a vocabulary that is useful beyond one legal system: personal data, processing, data subject, controller, processor, rights, safeguards, and accountability. GDPR is one important source for this vocabulary, but the concepts are useful for reading many regulations.

### Hospital lens

These words help translate a messy hospital workflow into governance questions: who decides, who acts, why data is used, how much is needed, and how patients can exercise control.

# Personal Data and Identifiability

## Core idea

Personal data is any information relating to an identified or identifiable natural person. A person may be identified directly, or indirectly through identifiers, location, online IDs, or physical, genetic, economic, cultural, social, or other characteristics [European Union, 2016].

## Running example

“Patient 1042” may still be personal data if the hospital can link that number to a name. A rare disease plus village plus admission date may also identify someone indirectly.

# The Identifiability Test

## Reasonable means

Identifiability depends on what the controller or another party can reasonably use, considering cost, time, available technology, and likely future developments.

## Running example

A dataset with ages, postal codes, rare diagnoses, and dates may look anonymous. If local staff can match it with appointment schedules, it may still identify patients.

# Anonymization vs Pseudonymization

## Different risk levels

**Anonymization** aims to make re-identification no longer reasonably possible. **Pseudonymization** replaces direct identifiers with codes, but someone can still re-link the data using additional information.

## Running example

Removing names from lab results is not enough if a separate key links code P-1042 to Maria. That is pseudonymized data, not anonymous data.

# Processing Means Almost Everything

## Processing

Processing includes collecting, recording, organizing, storing, changing, consulting, using, transmitting, making available, comparing, linking, restricting, erasing, and destroying data.

## Running example

When a nurse opens a record, a lab uploads a result, a backup stores the database, or a research team receives an export, each action is processing.

# Controller and Processor

## Responsibility structure

The **controller** determines purposes and means. The **processor** processes personal data on behalf of the controller. Joint controllers may exist when multiple parties jointly decide why and how processing happens.

## Running example

St. Isidore Hospital decides to use an EHR for patient care: it is the controller. A hosting provider that runs the database under hospital instructions is usually a processor.

# Data Protection Scope and Balance

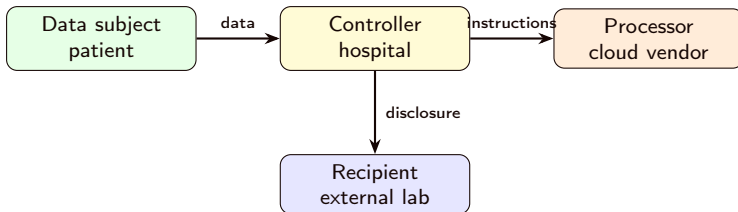
## Object

Data protection protects natural persons with regard to personal-data processing, but it does not mean stopping all data flows. It balances privacy, legitimate information use, care delivery, research, public health, and non-discrimination.

## Running example

A hospital should not block every data transfer in the name of privacy. It should allow necessary care, public health, and research flows under defined safeguards.

# Actors in a Data Processing Workflow





# Recap: Privacy and Data Protection

## Takeaways

- Personal data depends on identifiability, including indirect identifiability.
- Pseudonymized data can still be personal data.
- Governance starts by naming actors, purposes, and processing operations.

## In St. Isidore Hospital

St. Isidore can now describe a patient-data workflow before deciding whether it is lawful or safe.

## Fair Processing Principles

## Section Context: Fair Processing Principles

### What we are talking about

Modern data protection law does not only ask whether data is secret. It asks whether processing is **fair**: understandable, limited to a real purpose, proportionate, accurate, secured, and governed by someone who can explain the choices made.

### Hospital lens

The same patient record may be appropriate for treatment, inappropriate for curiosity, and too broad for research unless the hospital defines the purpose and limits the data flow.

# Purpose and Minimization

## Practical rule

Before collecting or sharing data, describe the purpose in plain language and remove fields that are not necessary for that purpose. A fair process starts by asking “what do we actually need?”

## Running example

A lab referral needs patient identity, requested exam, specimen information, and clinical context. It usually does not need unrelated psychiatric notes or family financial details.

# Accuracy, Storage, and Security

## Practical rule

Fair treatment requires data to remain reliable, retained for a justified time, and protected against unauthorized access or alteration. Privacy and security meet here: bad or exposed data can directly harm patients.

## Running example

An outdated allergy field, an old record kept without reason, or an exposed HIV result are different failures, but all break fair treatment of patient data.

# Accountability

## Core idea

Accountability means the organization can show how it handles data: mapped workflows, assigned responsibilities, access rules, security controls, retention choices, logs, and review.

## Running example

If a patient asks why their record was shared with an external laboratory, the hospital should be able to reconstruct the purpose, the fields shared, the recipient, and the safeguards.

# Recap: Privacy and Data Protection

## Takeaways

- Fair processing is about purpose, proportionality, transparency, security, and evidence.
- Privacy is not solved by a consent box or by secrecy alone.
- A hospital should be able to explain why data moves and how patients are protected.

## In St. Isidore Hospital

St. Isidore must document why each data use exists, why the chosen data is necessary, and how the workflow remains trustworthy.

# Principles Behind Fair Processing

| Principle                     | Hospital question                                                                     |
|-------------------------------|---------------------------------------------------------------------------------------|
| Transparency                  | Can patients and staff understand what data is used and why?                          |
| Purpose limitation            | Is the use tied to a clear care, billing, research, or public-health purpose?         |
| Data minimization             | Are we collecting only the fields needed for that purpose?                            |
| Accuracy                      | Is the allergy, diagnosis, result, or contact data correct enough for safe decisions? |
| Storage limitation            | Do we keep the data only as long as there is a justified reason?                      |
| Integrity and confidentiality | Is the data protected against unauthorized access, loss, and alteration?              |
| Accountability                | Can the hospital explain and prove its data-handling choices?                         |



# Final Recap: Privacy and Data Protection

## Core lesson

Healthcare privacy is not only confidentiality. It is the governance of identifiable health data throughout its life cycle: defined purpose, minimal use, transparency, security, accountability, and evidence.

## In St. Isidore Hospital

St. Isidore can use EHRs, APIs, labs, research datasets, and AI tools, but each data flow must have a reason, a limit, a safeguard, and someone accountable for it.

# Sierra Leone: Track the Emerging Framework

## Main idea

Everything in this section becomes concrete through **regulation**: policies, laws, regulators, organizational duties, and professional rules.

## Sierra Leone context

Sierra Leone has been developing a national data-protection framework. After consultations and final validation of a Data Protection and Right to Access Information Bill in November 2025, Cabinet approved the country's first National Data Protection Policy on April 21, 2026, and authorized work toward a new Act and unified authority

[Ministry of Information and Civic Education Sierra Leone, 2025, Ministry of Information and Civic Education Sierra Leone, 2026].

Healthcare organizations should track the final law and implementation guidance as they are issued.

# Operational Security

# How This Lesson Progresses

## Learning path

This lesson is about **daily operational security** for people who handle healthcare data. We move from patient-data responsibility, to scams, accounts, devices, networks, backups, ransomware warning signs, and reporting.

## Hospital storyline

At St. Isidore Hospital, a receptionist, nurse, cashier, lab technician, and ward manager all touch patient data. None of them writes security software, but each can prevent or worsen a security and privacy incident through ordinary choices.

# From Course Concepts to Daily Practice

## Closing idea

The course introduced confidentiality, integrity, availability, risk, encryption, access control and privacy. This final lesson connects them to everyday behavior: **what staff do with screens, passwords, files, messages, devices, and conversations.**

## Running example

At St. Isidore Hospital, encryption protects a record in transit, access control limits who can open it, and privacy principles explain why only necessary data should be used. Operational security is the human layer that keeps those protections from being bypassed by haste, curiosity, convenience, or scams.

# What This Lesson Is Not

## Scope

We are not designing cryptographic protocols, firewall policies, or legal compliance programs. We are asking: **what should a person do while using hospital systems, email, files, phones, and networks?**

## Running example

If a lab technician receives an unusual file, the important skill is not malware reverse engineering. It is pausing, checking, reporting, and avoiding actions that expose patients.

# Where Everyday Danger Comes From

## Not only hackers

Operational risk does not only come from advanced attackers. It also comes from ordinary work: wrong recipients, printed documents, shared accounts, public conversations, personal cloud storage, unapproved apps, lost phones, removable media, rushed approvals, and unclear handovers.

## Hospital lens

A patient list sent to the wrong WhatsApp group, a discharge note left at the printer, or a shared “night shift” password can expose patients even when the hospital network and encryption are working correctly.

## Healthcare Data Handling Mindset





## Section Context: Healthcare Data Handling

### What we are talking about

Operational security starts from a simple fact: healthcare data belongs to patients' lives, not to the convenience of the person currently viewing it. Staff should access, use, share, and store only what their work requires.

### Hospital lens

A staff member may be allowed to open the electronic health record (EHR), but that does not mean it is appropriate to browse a neighbor's diagnosis or discuss a maternity visit in a public corridor.



# Minimum Necessary Behavior

## Practical rule

Use or disclose the **minimum necessary** data for the task. This is a common privacy principle: avoid unnecessary access and unnecessary sharing when a narrower use will do [HHS, 2013].

## Running example

The cashier may need patient identity and billing information. The cashier usually does not need full clinical notes, HIV status, psychiatric history, or family details.

# Common Privacy Mistakes

| Mistake                                   | Safer habit                                         |
|-------------------------------------------|-----------------------------------------------------|
| Talking about patients in public areas    | move to a private place or lower the detail         |
| Sending full files when a field is enough | send only the needed fields                         |
| Leaving screens visible                   | lock the session or turn the screen away            |
| Using personal messaging apps for records | use approved hospital channels                      |
| Curiosity access                          | open records only for assigned work                 |
| Leaving paper at printers or desks        | collect, file, or dispose of paper safely           |
| Sharing one account between colleagues    | use named personal accounts and approved delegation |



# Recap: Operational Security

## Takeaways

- Patient data should be handled with purpose and restraint.
- Authorized access is not the same thing as appropriate access.
- Privacy failures can come from ordinary conversations, screens, and messages.

## In St. Isidore Hospital

St. Isidore treats every patient record as a responsibility, not as a casual workplace object.

# Scams and Social Engineering



## Section Context: Scams

### What we are talking about

Many attacks begin by tricking a person. The U.S. Cybersecurity and Infrastructure Security Agency (CISA), a public cybersecurity agency, and the U.S. Department of Health and Human Services (HHS), the federal health department, both emphasize phishing, social engineering, and basic cybersecurity training as core operational defenses [CISA, 2025, HHS, 2026].

### Hospital lens

Attackers do not need to break encryption if they can make a busy employee click, log in, approve, pay, download, or disclose.

# Common Healthcare Scams

| Scam                                | Hospital example                                     |
|-------------------------------------|------------------------------------------------------|
| Phishing attachment                 | "Updated rota" spreadsheet asks to enable macros     |
| Credential harvesting               | fake patient portal login page steals passwords      |
| Multi-factor authentication fatigue | repeated approval prompts until someone accepts      |
| Fake tech support                   | caller asks a nurse to install a remote-control tool |
| Invoice fraud                       | supplier asks to change bank account urgently        |
| Executive impersonation             | director seems to request a patient list by email    |

# Pause Signals

## Red flags

Slow down when a message has urgency, fear, secrecy, mismatched domains, unexpected attachments, password requests, unknown links, unusual payment instructions, or pressure to bypass procedure.

## Running example

An email says: "Your mailbox will close today. Login now before surgery schedules are deleted." The safer action is to report it and use the normal information-technology support contact, not the link.



# How to Verify

## Simple verification

Use a second channel that the attacker did not provide. Call the known hospital number, open the official website yourself, ask the supervisor in person, or use the approved helpdesk channel.

## Running example

If “information-technology support” calls asking for a password, hang up and call the real helpdesk number. Real support should not need your password.

# Recap: Operational Security

## Takeaways

- Scams exploit pressure and routine.
- A secure user pauses before clicking, approving, paying, or sharing.
- Reporting suspicious messages is a protective action, not an admission of failure.

## In St. Isidore Hospital

St. Isidore makes it easy for staff to verify unusual requests without delaying urgent care.

## Accounts, Passwords, and Multi-Factor Authentication



## Section Context: Accounts

### What we are talking about

Accounts are doors into patient data. Staff do not need to understand password hashing to act well: they need unique passwords, a password manager where approved, multi-factor authentication, and the habit of never sharing credentials.

### Hospital lens

If a receptionist reuses the same password for email, social media, and the electronic health record, one leaked account can become access to patient records.

# Strong Passwords

## Practical rule

Use passwords that are **long, unique**, and hard to guess. The Cybersecurity and Infrastructure Security Agency recommends strong, unique passwords and notes that long passphrases or random passwords are stronger than short, reused ones [CISA, 2025].

## Running example

Makeni2026! is guessable and reusable. A longer passphrase or a random password generated by an approved password manager is safer.

# Password Managers

## Definition

A **password manager** stores passwords in an encrypted vault and can generate unique passwords for each account. It reduces the temptation to reuse passwords or write them in unsafe places [CISA, 2026b].

## Running example

Instead of keeping electronic health record, email, payroll, and supplier passwords in a notebook, a staff member uses the approved manager and protects it with one strong master password and multi-factor authentication.



# Multi-Factor Authentication

## Definition

**Multi-factor authentication** asks for two or more proof types: something you know (password), something you have (phone, token, security key), or something you are (biometric). The Cybersecurity and Infrastructure Security Agency recommends multi-factor authentication wherever possible, especially for sensitive data and remote access [CISA, 2026a].

## Running example

If a password is stolen by a fake login page, multi-factor authentication can stop the attacker unless the user also approves the attacker's login prompt.

# Multi-Factor Authentication Fatigue

## Attack pattern

In a **multi-factor authentication fatigue** attack, the attacker already has the password and repeatedly sends login approval requests until the user taps approve. Unexpected approval prompts should be treated as warning signs.

## Running example

At 23:40, a nurse receives repeated login prompts while at home. The safe response is deny, change the password through the official path, and report the event.





# Recap: Operational Security

## Takeaways

- Passwords must be unique because breaches in one place can spread to another.
- Password managers make strong passwords usable.
- Multi-factor authentication helps, but unexpected prompts must be denied and reported.

## In St. Isidore Hospital

St. Isidore protects patient data by making account compromise harder and easier to notice.

## Devices, Updates, and Workspaces



## Section Context: Devices

### What we are talking about

Patient data is handled through laptops, desktops, phones, tablets, printers, Universal Serial Bus (USB) drives, and shared workstations. A careless device becomes a patient-data risk.

### Hospital lens

A ward computer left unlocked can expose more data than a sophisticated attack, because the next person sees the open record with a legitimate session.

# Install Security Updates

## Practical rule

Keep operating systems, browsers, office software, and approved clinical software updated. The Cybersecurity and Infrastructure Security Agency and the Federal Trade Commission (FTC) both treat software updates as a basic protection against known attacks [CISA, 2025, FTC, 2026a].

## Running example

A lab computer postpones updates for weeks because it is “always busy.” That delay can leave a known vulnerability open to malware delivered by email or a website.

# Do Not Install Unapproved Software

## Practical rule

Install only approved applications and browser extensions. Avoid cracked software, unknown remote support tools, free converters for patient files, and USB utilities from untrusted sources.

## Running example

A “free PDF compressor” website or app may upload patient discharge letters to an external service. That is both a security and privacy problem.

# Lock Screens and Clear Desks

## Practical rule

Lock the workstation when stepping away, collect printouts immediately, avoid sticky-note passwords, and position screens so visitors cannot read patient data.

## Running example

At reception, the next patient should not see the previous patient's address, diagnosis, or payment status on the monitor or printer tray.



# Paper, Photos, and Messaging Apps

## Practical rule

Treat paper records, screenshots, photos, and chat messages as patient data. Do not photograph records, send clinical details through personal messaging apps, or leave printed documents where patients, visitors, or unauthorized colleagues can read them.

## Running example

A nurse photographs a wound chart with a personal phone to “remember it later.” Even if the intention is clinical, the image may sync to a personal cloud account or be visible to family members using the phone.



# Recap: Operational Security

## Takeaways

- Updates close known doors attackers already know how to use.
- Approved tools matter because patient data can leak through convenience apps.
- Physical habits, paper handling, and messaging choices protect digital privacy.

## In St. Isidore Hospital

St. Isidore treats devices and desks as part of the patient-data environment.



# Networks and Remote Work



## Section Context: Networks

### What we are talking about

Staff often work from offices, wards, homes, hotels, conferences, and phones. The network matters because patient data may travel through it.

### Hospital lens

Checking laboratory results from a hospital workstation is different from downloading patient lists on a personal laptop over a cafe network.

# Public Networks

## Practical rule

Avoid sensitive healthcare work on public or untrusted networks. If remote access is necessary, use approved hospital tools, HTTPS services, and the official virtual private network (VPN) where required. HTTPS is the secure version of web browsing that encrypts traffic between the browser and the website. Federal Trade Commission guidance notes that public Wi-Fi can expose personal information unless traffic is protected [FTC, 2026a].

## Running example

A doctor waiting at an airport should not download a spreadsheet of patient records to a personal device just because the airport Wi-Fi works.

# Home and Remote Access

## Practical rule

Use hospital-approved devices where possible, keep home Wi-Fi protected with a strong password, do not share work devices with family, and log out when finished. Remote access should use multi-factor authentication and approved secure connections [FTC, 2026b].

## Running example

A ward manager working from home should not let a child use the same logged-in laptop for homework while patient reports are open.

# Recap: Operational Security

## Takeaways

- The safest network is the approved work environment.
- Public networks require extra caution, even when websites use HTTPS.
- Remote work must protect the device, account, connection, and surrounding room.

## In St. Isidore Hospital

St. Isidore treats remote access as clinical work leaving the building.

## Backups, Ransomware, and Reporting

## Section Context: Continuity

### What we are talking about

Staff may not design backups, but they depend on them. They should know where important work is stored, avoid keeping the only copy on a personal device, and report signs of ransomware early.

### Hospital lens

If a nurse keeps the only copy of a clinic roster on a USB drive, losing the drive becomes both a continuity issue and a privacy issue.

# What Staff Should Back Up

## Practical rule

Save work in approved systems or approved shared storage that is backed up. Avoid personal email, personal cloud drives, local desktops, and removable media unless explicitly approved.

## Running example

The lab result register should live in the approved system or shared hospital folder, not only on one technician's laptop.



# Ransomware Warning Signs

## What to notice

Report sudden file renaming, ransom notes, files that will not open, unexpected password prompts, disabled security tools, unusual slowness, or a device behaving strangely after opening a file. Cybersecurity and Infrastructure Security Agency ransomware guidance emphasizes prevention, protected backups, and fast reporting [CISA, 2023].

## Running example

If a shared folder suddenly fills with files ending in a strange extension, disconnect from the network if instructed locally and report immediately. Do not keep trying to open more files.

# Report Early

## Practical rule

Report suspicious emails, lost devices, wrong recipients, accidental disclosures, strange logins, malware warnings, and unauthorized patient access. Early reporting gives the hospital time to limit harm.

## Running example

Sending a discharge letter to the wrong person is embarrassing, but hiding it is worse. Reporting quickly may allow recall, patient support, and proper documentation.

# Recap: Operational Security

## Takeaways

- Store work where it is backed up and governed.
- Ransomware often has visible warning signs before everything fails.
- Reporting quickly protects patients and colleagues.

## In St. Isidore Hospital

St. Isidore makes “I may have made a mistake” a starting point for containment, not blame.

## Practical Daily Checklist

# Before You Access Patient Data

## Ask yourself

- Do I need this data for my assigned work?
- Am I using the approved system, device, and network?
- Is anyone nearby able to see or hear more than they should?
- Am I about to copy, export, or send more than necessary?
- Am I using my own named account, not someone else's?

# Before You Share Patient Data

## Ask yourself

- Is this the right recipient, and did I select the correct address or chat?
- Is this the approved channel for patient information?
- Can I remove identifiers, fields, screenshots, or attachments that are not needed?
- Will this create an uncontrolled copy on a phone, personal email, or personal cloud?

# If Something Feels Wrong

## Stop and report

Do not click further, approve prompts, forward files, delete evidence, or try to fix suspicious behavior alone. Preserve what you can see, write down what happened, and contact the approved support channel.

## Running example

After opening a suspicious attachment, a receptionist reports the email, time, attachment name, and what appeared on screen. That information may help protect the whole hospital.

# Final Recap

## Core lesson

Operational security for healthcare data is mostly ordinary discipline: use only needed data, protect accounts, question suspicious requests, update devices, avoid risky networks, control paper and messages, store work in approved places, and report problems early.

## In St. Isidore Hospital

St. Isidore Hospital does not rely on every staff member becoming a security engineer. It relies on every staff member making small, repeatable choices that keep patient data and care safer.



## Glossary and Resources

## Final Glossary

# Final Glossary I

- **Algorithm:** precise steps for solving a problem, such as encrypting, hashing, or verifying data.
- **Binary system:** representation based on 0s and 1s; computers store text, images, packets, and encrypted data as bits.
- **Digital encoding:** a rule for representing information as bits. Encoding makes data processable; encryption makes it unreadable without a key.
- **Computer network:** connected devices that exchange data, such as hospital workstations, servers, lab systems, and medical devices.
- **Client:** a device or application that requests a service, such as a ward workstation opening a patient record.
- **Server:** a system that provides services or data to clients, such as an EHR server returning patient information.

# Final Glossary II

- **LAN:** Local Area Network; a network in a limited place, such as a ward, office, or hospital building.
- **Wi-Fi:** wireless local networking; devices connect by radio instead of a cable.
- **Private network:** limited to an organisation or group, such as a hospital LAN or a protected clinical subnet.
- **Public network:** reachable by many outside parties, such as the public internet or a hospital guest Wi-Fi.
- **Internet:** the global network of interconnected networks.
- **Firewall:** a control that allows, blocks, or logs traffic according to rules such as source, destination, port, protocol, or application context.
- **VPN:** a Virtual Private Network; an encrypted tunnel over a possibly insecure network, often the public internet, connecting users, offices, or services through a protected path.

## Additional Materials

## Additional Practice References

### Caesar cipher playground

For a quick visual experiment with a historical substitution cipher, use Cryptii's Caesar cipher tool:

<https://cryptii.com/pipes/caesar-cipher/>

### How to use it

Encrypt a short hospital-style phrase such as LAB RESULT READY, then change the shift and observe how easy the structure remains to test by hand.

# Additional Practice Tools: Encryption

## RSA tool

For a quick experiment with public-key encryption, use this RSA tool:  
<https://www.devglan.com/online-tools/rsa-encryption-decryption>

## How to use it

Try encrypting a short referral note with a public key, then observe that the matching private key is needed to recover the original text.

# Additional Practice Tools: Symmetric Encryption



## AES tool

For a quick experiment with symmetric encryption, use this AES tool:  
<https://www.devglan.com/online-tools/aes-encryption-decryption>

## How to use it

Encrypt a short message such as WARD BACKUP READY and verify that changing the key prevents correct decryption.



# Additional Practice Tools: Hashes and HMAC

## SHA file hash

For a quick experiment with file fingerprints, use this SHA file hash generator:

<https://www.devglan.com/online-tools/file-hash-generator>

## How to use it

Hash a small text file, change one character, and compare the two outputs to see how sensitive a hash is to modification.

# Additional Practice Tools: HMAC

## HMAC-SHA256 tool

For a quick experiment with keyed message authentication, use this HMAC-SHA256 tool:

<https://www.devglan.com/online-tools/hmac-sha256-online>

## How to use it

Compute a tag for a lab-result message, then change either the message or the shared secret and observe that the tag changes.

## Additional Reading on Malware

### Malware taxonomy

Fortinet's malware overview is useful as a glossary-style reference for common malware categories:

https:

[//www.fortinet.com/resources/cyberglossary/types-of-malware](https://www.fortinet.com/resources/cyberglossary/types-of-malware)

### How to use it

Use it to connect Lesson 1 threat vocabulary with operational examples: ransomware, spyware, worms, trojans, and social-engineering delivery paths.

# Healthcare Data Privacy and Security

Giuseppe Pisano  
g.pisano@unibo.it

August, 2026



S.K.I.L.L.E.D — AID013244/04/2

Strategic Knowledge and Inclusive Lifelong Learning in the health sector for youth Employability and Development

# References I

[CISA, 2023] CISA (2023).

Stopransomware guide

<https://www.cisa.gov/stopransomware>.

[CISA, 2025] CISA (2025).

Four cybersecurity essentials for sltts

<https://www.cisa.gov/resources-tools/resources/four-cybersecurity-essentials-sltts>.

[CISA, 2026a] CISA (2026a).

Require multifactor authentication

<https://www.cisa.gov/audiences/small-and-medium-businesses/secure-your-business/require-multifactor-authentication>.

[CISA, 2026b] CISA (2026b).

Use a password manager to create and remember strong passwords

<https://www.cisa.gov/resources-tools/training/cyb3rsmrt-use-password-manager-create-and-remember-strong-passwords>.

[Council of Europe, 1950] Council of Europe (1950).

European convention on human rights

<https://www.echr.coe.int/european-convention-on-human-rights>.

# References II

[Diffie and Hellman, 1976] Diffie, W. and Hellman, M. E. (1976).  
New directions in cryptography.  
*IEEE Transactions on Information Theory*, 22(6):644–654  
DOI:10.1109/TIT.1976.1055638.

[European Union, 2016] European Union (2016).  
Regulation (eu) 2016/679, general data protection regulation  
<https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng>.

[Ferraiolo et al., 2001] Ferraiolo, D. F., Sandhu, R., Gavrila, S., Kuhn, D. R., and  
Chandramouli, R. (2001).  
Proposed nist standard for role-based access control.  
Technical report, National Institute of Standards and Technology  
<https://csrc.nist.gov/publications/detail/conference-paper/2001/10/01/proposed-nist-standard-for-role-based-access-control/final>.

[FTC, 2026a] FTC (2026a).  
Are public wi-fi networks safe? what you need to know  
<https://consumer.ftc.gov/articles/are-public-wi-fi-networks-safe-what-you-need-know>.

# References III

[FTC, 2026b] FTC (2026b).

Cybersecurity for small business

<https://www.ftc.gov/business-guidance/small-businesses/cybersecurity>.

[HHS, 2013] HHS (2013).

Minimum necessary requirement

<https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/minimum-necessary-requirement/index.html>.

[HHS, 2026] HHS (2026).

Health industry cybersecurity practices

<https://hhscyber.hhs.gov/cornerstone-hicp.html>.

[Informatici Senza Frontiere, 2026a] Informatici Senza Frontiere (2026a).

Open hospital

<https://github.com/informatici/OpenHospital>.

[Informatici Senza Frontiere, 2026b] Informatici Senza Frontiere (2026b).

*Open Hospital Administrator's Guide*

[https://www.open-hospital.org/wp-content/OH\\_manuals/admin/AdminManual.html](https://www.open-hospital.org/wp-content/OH_manuals/admin/AdminManual.html).

[Informatici Senza Frontiere, 2026c] Informatici Senza Frontiere (2026c).

*Open Hospital User's Guide*

[https://www.open-hospital.org/wp-content/OH\\_manuals/user/UserManual.html](https://www.open-hospital.org/wp-content/OH_manuals/user/UserManual.html).

## References IV

[Initiative, 2012] Initiative, J. T. F. T. (2012).

Guide for conducting risk assessments.

Special Publication 800-30 Revision 1, National Institute of Standards and Technology

DOI:10.6028/NIST.SP.800-30r1.

[Kerckhoffs, 1883] Kerckhoffs, A. (1883).

La cryptographie militaire.

*Journal des sciences militaires*, 9:5–38

[Ministry of Information and Civic Education Sierra Leone, 2025] Ministry of Information and Civic Education Sierra Leone (2025).

Moice concludes final national validation of the data protection and right to access information bill 2025

<https://moice.gov.sl/moice-concludes-final-national-validation-of-the-data-protection-and-right-to-access-information-bill-2025/>.

[Ministry of Information and Civic Education Sierra Leone, 2026] Ministry of Information and Civic Education Sierra Leone (2026).

Cabinet approves first ever data protection policy, paving way for new data law

<https://moice.gov.sl/cabinet-approves-first-ever-data-protection-policy-paving-way-for-new-data-law/>.



# References V

- [National Institute of Standards and Technology, 2004] National Institute of Standards and Technology (2004).  
Standards for security categorization of federal information and information systems.  
Federal Information Processing Standards Publication 199, National Institute of Standards and Technology  
[DOI:10.6028/NIST.FIPS.199](https://doi.org/10.6028/NIST.FIPS.199).
- [National Institute of Standards and Technology, 2015] National Institute of Standards and Technology (2015).  
Secure hash standard (shs).  
Federal Information Processing Standards Publication 180-4, National Institute of Standards and Technology  
[DOI:10.6028/NIST.FIPS.180-4](https://doi.org/10.6028/NIST.FIPS.180-4).
- [National Institute of Standards and Technology, 2023a] National Institute of Standards and Technology (2023a).  
Advanced encryption standard (aes).  
Federal Information Processing Standards Publication 197, National Institute of Standards and Technology  
[DOI:10.6028/NIST.FIPS.197-upd1](https://doi.org/10.6028/NIST.FIPS.197-upd1).

# References VI

- [National Institute of Standards and Technology, 2023b] National Institute of Standards and Technology (2023b).  
Digital signature standard (dss).  
Federal Information Processing Standards Publication 186-5, National Institute of Standards and Technology  
DOI:10.6028/NIST.FIPS.186-5.
- [Saltzer and Schroeder, 1975] Saltzer, J. H. and Schroeder, M. D. (1975).  
The protection of information in computer systems.  
*Proceedings of the IEEE*, 63(9):1278–1308  
DOI:10.1109/PROC.1975.9939.
- [Shirey, 2007] Shirey, R. (2007).  
Internet security glossary, version 2.  
RFC 4949, Internet Engineering Task Force  
DOI:10.17487/RFC4949.
- [United Nations, 1948] United Nations (1948).  
Universal declaration of human rights  
<https://www.un.org/en/about-us/universal-declaration-of-human-rights>.

# References VII



[Warren and Brandeis, 1890] Warren, S. D. and Brandeis, L. D. (1890).  
The right to privacy.  
*Harvard Law Review*, 4(5):193–220